

# An Insight into Security Code Review with LLMs: Capabilities, Obstacles, and Influential Factors

Jiaxin Yu<sup>a</sup>, Peng Liang<sup>a,\*</sup>, Yujia Fu<sup>a</sup>, Amjed Tahir<sup>b</sup>, Mojtaba Shahin<sup>c</sup>, Chong Wang<sup>a,\*</sup> and Yangxiao Cai<sup>a</sup>

<sup>a</sup>*School of Computer Science, Wuhan University, China*

<sup>b</sup>*School of Mathematical and Computational Sciences, Massey University*

<sup>c</sup>*School of Computing Technologies, RMIT University, Australia*

## ARTICLE INFO

### Keywords:

Large Language Model, Code Review, Security Analysis

## ABSTRACT

Security code review is a time-consuming and labor-intensive process typically requiring integration with automated security defect detection tools. However, existing security analysis tools struggle with poor generalization, high false positive rates, and coarse detection granularity. Large Language Models (LLMs) have been considered promising candidates for addressing those challenges. In this study, we conducted an empirical study to explore the potential of LLMs in detecting security defects during code review. Specifically, we evaluated the performance of seven LLMs under five different prompts and compared them with state-of-the-art static analysis tools. We also performed linguistic and regression analyses for the two top-performing LLMs to identify quality problems in their responses and factors influencing their performance. Our findings show that: (1) In security code review, LLMs significantly outperform state-of-the-art static analysis tools, and the reasoning-optimized LLM performs better than general-purpose LLMs. (2) DeepSeek-R1 achieves the highest performance, followed by GPT-4. The optimal prompt for DeepSeek-R1 incorporates both the commit message and chain-of-thought (CoT) guidance, while for GPT-4, the prompt with a Common Weakness Enumeration (CWE) list works best. (3) GPT-4 frequently produces vague expressions and exhibits difficulties in accurately following instructions in the prompts, while DeepSeek-R1 more commonly generates inaccurate code details in its outputs. (4) LLMs are more adept at identifying security defects in code files that have fewer tokens and security-relevant annotations.

## 1. Introduction

Security defects are potential security risks or weaknesses in the system introduced during implementation (Paul et al., 2021). Once attackers maliciously exploit a security defect, it could lead to serious consequences, including data breaches, financial losses, and service disruptions (Telang and Wattal, 2007; Cavusoglu et al., 2004). The longer a security defect stays in the program, the higher its associated fixing and maintenance costs are (Planning, 2002). Thus, many organizations are shifting security analysis to earlier stages of software development, typically at code review time (GitLab, 2022). Code review is a human-intensive process in which the reviewer examines the code submitted by the developer to detect bugs, verify the implementation of the specification, ensure compliance with guidelines, and ensure quality. During this process, the reviewer raises issues in the code, discusses them with the developer, and provides recommendations. Adopting security analysis in code review can incorporate diverse viewpoints from both reviewers and developers, and effectively prevent security defects created by programmers working alone, as they naturally have a limited perspective of potential security risks (Weir et al., 2017), from being merged into the source

code repository. In this study, we focus on security analysis in the context of code review, referring to it as *security code review* (Edmundson et al., 2013).

Security code review is increasingly integrated into the development pipelines by project teams (Paul et al., 2021). Its resource-intensive nature, which requires significant human effort and time to review and revise the code, poses a notable challenge, particularly in popular large-scale open-source projects with numerous contributions (Guo et al., 2024). Therefore, it has been desired to develop effective automated tools to assist code reviewers in security code review. Despite various static/dynamic/hybrid program analysis tools being proposed, they each encounter practical challenges, such as excessive imprecision (Nong et al., 2021), high false positive rates (Johnson et al., 2013; Sui et al., 2020), input range limitations (Haller et al., 2013), and weak scalability (Nong et al., 2021).

Several data-driven approaches based on machine learning (ML)/deep learning (DL) have been developed for vulnerability detection and repair, which can somewhat handle the challenges encountered by traditional program analysis tools (Chakraborty et al., 2021). However, due to the lack of sizable and realistic training datasets (Nong et al., 2022), those approaches inevitably lacked robustness and tended to fall short when implemented in unfamiliar, real-world projects (Nong et al., 2024a). Nong et al. (2024b) found that even using the training dataset augmented by the latest vulnerability injection technique, the highest F1 score and the top-1 accuracy that state-of-the-art DL-based vulnerability

\*Corresponding author.

✉ jiaxinyu@whu.edu.cn (J. Yu); liangp@whu.edu.cn (P. Liang); yujia\_fu@whu.edu.cn (Y. Fu); a.tahir@massey.ac.nz (A. Tahir); mojtaba.shahin@rmit.edu.au (M. Shahin); cwang@whu.edu.cn (C. Wang); yangxiaocai@whu.edu.cn (Y. Cai)

ORCID(s):

detection and repair tools can achieve on the dataset constructed from real-world projects are still limited, at 20.01% and 21.05% respectively. Therefore, it remains essential to further explore techniques with better generalization and robustness to address vulnerabilities in real-world projects.

Recently, pre-trained LLMs have demonstrated promising performances across a broad spectrum of software engineering tasks, such as program repair (Jiang et al., 2023), test generation (Kang et al., 2023; Schäfer et al., 2023), and specification generation (Xie et al., 2023). Such models can understand and generate explanatory natural language responses, and are thus considered a potential candidate for security code review. We expect that LLM can act as a code reviewer, not only identifying security defects in code files, but also explaining the specific defect scenarios in detail to developers in a human-readable way. Applying LLMs to support security code review can help detect security defects earlier and improve productivity by helping code reviewers check their code faster and more efficiently. However, applying LLMs in the specific field of security code review remains largely unexplored.

Many studies have focused on leveraging LLMs for vulnerability detection. Zhou et al. (2024) evaluated the capabilities of GPT-3.5 and GPT-4 in vulnerability detection under few-shot learning prompts, while Purba et al. (2023) compared LLMs with static analysis tools in detecting software vulnerabilities. These studies mainly conducted a coarse-grained assessment of LLMs in binary classification tasks to judge whether there were security defects in the code. They did not require LLMs to provide more detailed information, such as the location and type of vulnerability. Researchers have also developed prompting strategies to enhance the effectiveness of LLMs in vulnerability detection, such as the DL-based prompting framework proposed by Yang et al. (2024) and the vulnerability-semantic guided prompting approach formulated by Nong et al. (2024a). However, the datasets utilized in these studies are synthetic and CVE datasets, which do not fully represent real-world codebases.

**Motivated by the limitations mentioned above**, we aim to bridge the knowledge gap by conducting an empirical study to comprehensively explore the potential of LLMs in fine-grained security code review on a practical dataset constructed from real-world code repositories. Specifically, in this study, LLMs were requested to provide detailed information on the identified security defect, including its line number, type, specific description, and suggested fix. The dataset we utilized consists of 534 code review files obtained from four open-source projects (namely, OpenStack Nova and Neutron, and Qt Base and Creator). We evaluated the performance of LLMs, analyzed existing quality problems, and examined factors influencing their performance to offer insights into the real-world applicability and limitations of LLM in security code review. First, we identified five prompt templates to enhance LLMs (based on the prompting strategies formulated by Zhang et al. (2024)). Then, we compared the performance of 7 open-source and closed-source LLMs with static analysis tools across these

prompt templates in detecting security defects identified by reviewers. After collecting the responses generated by the two best-performing LLMs with their respective optimal prompts, we manually extracted quality problems present in these responses. We also used these responses to construct two separate cumulative link mixed models to explore the impact of 11 factors on the performance of each LLM. Our **findings** reveal that: (1) LLMs outperform state-of-the-art static analysis tools in security code review. Among LLMs, the reasoning-optimized model surpasses general-purpose models. (2) DeepSeek-R1 is the best-performing LLM, followed by GPT-4. For DeepSeek-R1, the prompt including the commit message and CoT instruction is the most effective, while for GPT-4, the prompt with a CWE list works best. (3) GPT-4 struggles with vague expressions and poor instruction-following, while DeepSeek-R1 is more prone to producing incorrect code details in its responses. (4) LLMs detect security defects more effectively in code files with fewer tokens and security-related annotations. In summary, this study makes the following **contributions**: (1) We conducted a fine-grained evaluation of the capability of popular and representative LLMs in security code review. (2) We measured the impact of the non-determinism of LLMs on the consistency of security code review. (3) We identified quality problems and quantified hallucinations in the responses generated by the two top-performing LLMs, aiming to highlight the challenges faced by LLMs in security code review. (4) We carried out the first analysis of the factors that might influence the performance of LLMs in security code review.

**Paper Organization.** Section 6 surveys the related work. Section 2 describes the methodology employed in this study. Section 3 presents the results, followed by a discussion of the implications of our study results in Section 4. Section 5 clarifies the threats to validity. Finally, Section 7 concludes this work and outlines future directions. The replication package of this study has been provided online (Yu et al., 2025).

## 2. Methodology

### 2.1. Research Questions

This work aims to comprehensively assess the capability of LLMs to assist with security code review by automatically detecting security defects in the given code. We divided our study into three Research Questions (RQs), as shown below. The research procedure for each RQ is illustrated in Fig. 2.

**RQ1:** How effectively do LLMs detect security defects during code review?

RQ1.1: How effectively do LLMs perform security code reviews under the basic prompt?

RQ1.2: Can prompting with auxiliary information improve the performance of LLMs?

RQ1.3: Can the Chain-of-Thought (CoT) prompting approach improve the performance of LLMs?

**RQ1.4:** What is the impact of the non-determinism of LLMs on the consistency of security code review?

**Motivation.** Many studies have focused on the performance of LLMs in detecting security defects, but they often suffer from low-quality datasets collected automatically and a narrow detection scope primarily confined to function-level code (Zhou et al., 2025). To address these limitations, RQ1 utilizes a manually curated dataset to ensure data quality. It comprehensively evaluates the capability of LLMs to review a complete code file from real-world code reviews for security defects. Additionally, due to the inherent non-determinism of LLMs, the responses of LLMs may exhibit considerable divergence for the same prompt across different runs. Non-determinism is mainly caused by decoding configurations (Song et al., 2024), with other hypotheses such as floating point, unreliable GPU calculations (Ouyang et al., 2025), and its sparse MoE architecture failing to enforce per-sequence determinism (La Malfa et al., 2024; Puigcerver et al., 2023). Considering that the non-determinism of LLMs has not yet been studied when applied to security tasks, we conducted a quantitative analysis of the consistency of LLM responses to explore its impact on the task of security code review.

**RQ2:** What quality problems exist in LLM-generated responses during security code review?

**RQ2.1:** What is the distribution of quality problems in these responses?

**RQ2.2:** Which of these problems are hallucination-related, and what are their proportions?

**Motivation.** Kabir et al. (2024) noted that LLMs' responses may be verbose, inconsistent, and contain conceptual or logical errors, negatively impacting the quality of the answers. Among these problems, hallucination in particular has been extensively studied (Liu et al., 2024; Tonmoy et al., 2024). Hallucination refers to content generated by LLMs that appears plausible but lacks factual grounding (Huang et al., 2025). If we applied LLMs to real-world software development tasks, particularly during security code review, such hallucination may mislead practitioners, increase review costs, and even compromise system security. Previous studies have not yet thoroughly examined quality problems present in LLM-generated responses during security code review. RQ2 intends to conduct an in-depth linguistic analysis to investigate possible hallucination issues. First, we investigated the distribution of quality problems in LLMs' responses, such as *Vague statement*, *Incorrect concept*, and *Incomplete answer*. Then we identified hallucination-related issues among these problems and quantified their proportion to bridge the knowledge gap and highlight potential areas for improvement.

**RQ3:** Which factors influence the performance of LLMs in security code review?

**Motivation.** Previous studies have identified potential factors influencing the effectiveness of LLMs in detecting

security defects (Chen et al., 2023; Kabir et al., 2024; Zhou et al., 2023), primarily through case studies or observations. However, there is a lack of evidence substantiating such claims. RQ3 employs a regression analysis to validate whether these factors significantly impact the performance of LLMs. This RQ helps pinpoint areas of concern in applying LLMs to security code review and highlights possible improvement directions.

## 2.2. Data Collection

We leveraged the code review dataset constructed by Yu et al. (2023) and examined the capability of LLMs in security code review. The dataset contains 614 review comments, each identifying a specific security defect across 15 predefined types from four projects: OpenStack Nova and Neutron (almost entirely written in Python), and Qt Base and Creator (mostly in C++ with some portions in C, Objective-C++, and Python). These projects are the most active within OpenStack and Qt (Hirao et al., 2020) and have been widely used in code review-related studies (Han et al., 2022; Hamasaki et al., 2013; Spadini et al., 2018). For each security defect, we could not include the code from the entire patchset in our prompt, which is always too long and exceeds the input token limits of LLMs. Instead, we included only the code from the single file, where the reviewer commented to identify a security defect. The 614 security-related review comments were reorganized as follows:

First, we filtered out comments published at the patchset level, as such data cannot be located in a specific file to construct a prompt. Then, for each code file to which these comments correspond, we consolidated all security-related comments in the file and the corresponding security defect records into a single data item. Next, we utilized the Gerrit API to retrieve the content of each code file and the commit messages of the patchsets to which they belong. During this procedure, if we cannot obtain the content of the code files through the API, we ignore those files. Lastly, since 97% of the files in this dataset are Python and C/C++ files, we decided to remove any other files (all are configuration and scripting files) as those only formed  $\approx 3\%$  of the files and thus had a negligible impact on our results.

Our final dataset consists of 534 code files (258 Python and 276 C/C++ files), each including the source code, the commit message of the associated patchset, and detailed information of the **target security defects** as identified by the reviewers. We analyzed the distribution of security defect types in Python and C/C++ code files (see Fig. 3). In Python code files, the Python language employs automatic memory management and garbage collection. Therefore, *Memory Leak* and *Buffer Overflow* were relatively rare, while *Race Condition* was the most common type, accounting for 65.1%. In contrast, C/C++ requires programmers to manage memory and pointers manually, thus the C/C++ dataset has a more balanced distribution of security defects. In C/C++ code files, *Crash* was the most prevalent (32%), followed by *Race Condition* (17.4%), *Resource Leak* (16.3%) and *Integer Overflow* (14.9%). We also counted the lines of code

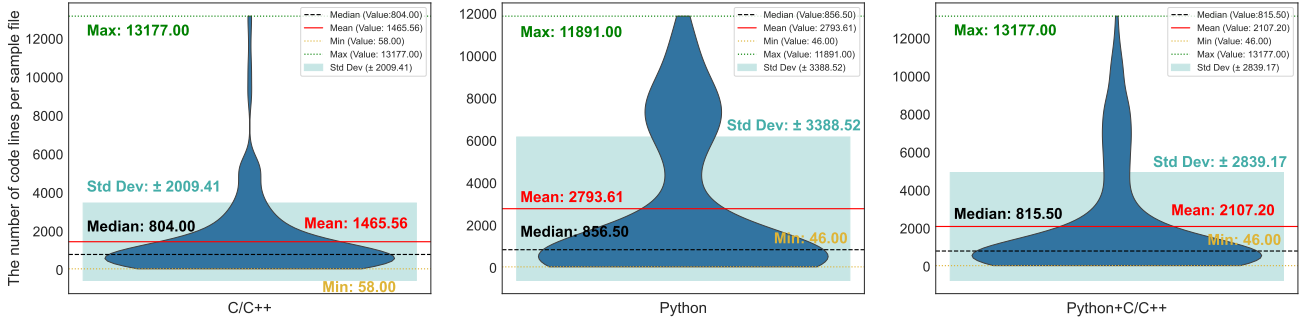


Figure 1: Distribution of LoC of the code files with security defects

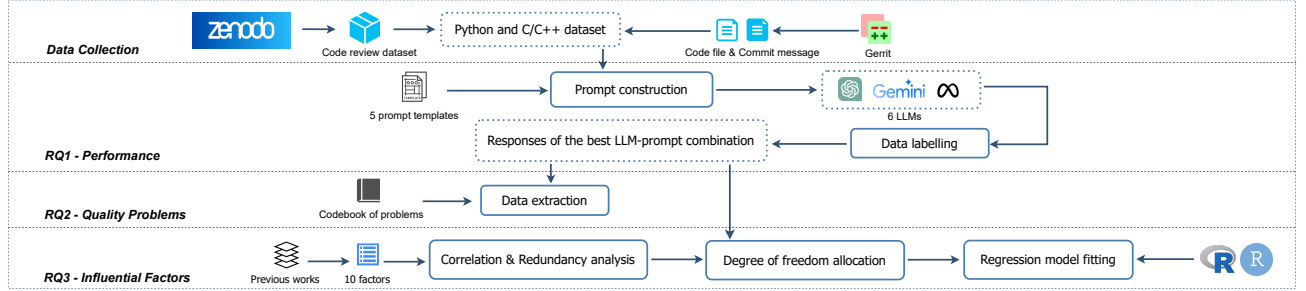


Figure 2: An overview of the research procedure for investigating the three RQs

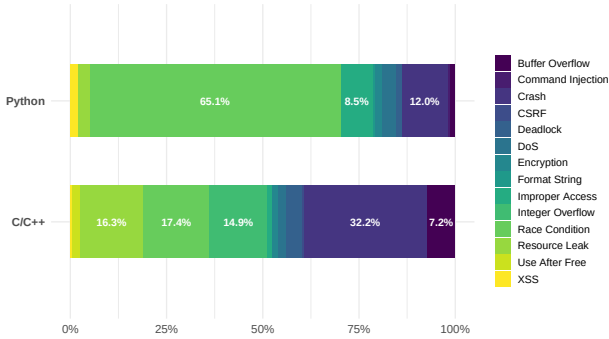


Figure 3: Distribution of security defect types on the Python and C/C++ dataset

(LoC) of the collected code files in our dataset. Fig. 1 shows the distribution of LoC for different languages (Python and C/C++, respectively) and the distribution of LoC for the entire dataset. We found that the median LoC is 815 and the average reaches 2,107, which substantially exceeds the scale of function-level datasets like Big-Vul (avg. 30 LoC) and SVEN (avg. 168 LoC) adopted in related studies (Yin et al., 2024; Steenhoek et al., 2024b).

## 2.3. Research Procedure of RQ1

### 2.3.1. LLM Selection

To fully evaluate the performance of LLMs in security defect detection, we firstly selected four representative LLMs from the proprietary GPT and Gemini families, along with two from the open-source Llama 2 family, which are the most popularly used LLMs when we started our experiments

in December 2023. Specifically, for proprietary LLMs, we chose GPT-3.5 and GPT-4 provided by the ChatGPT platform (May 2024 version), and GPT-4 Turbo and Gemini Pro accessed through the API. For open-source LLMs, we deployed the smallest and largest chat versions of models in the Llama 2 series—namely, Llama 2 7B and Llama 2 70B—on a server with eight NVIDIA GeForce RTX 4090 GPUs, each with 24 GB of VRAM. Given the rapid development of LLMs and the emergence of reasoning-optimized models, we additionally employed DeepSeek-R1 and accessed its updated version released on May 28, 2025 through the API. To realistically reflect on the practical capabilities of LLMs in security defect detection, we used the default hyperparameter settings throughout our experiments. Some studies mitigate the non-determinism of LLMs by setting the temperature to zero (Atil et al., 2024; Blackwell et al., 2024). In contrast, we refrained from doing so, as this may adversely affect the performance of the LLMs (Song et al., 2024) and may not guarantee determinism (Ouyang et al., 2025; Astekin et al., 2024). We retained the default temperature settings and quantified the non-determinism of LLMs as one aspect of performance evaluation in RQ1.4, rather than artificially suppressing such non-determinism via hyperparameter tuning. The versions, context windows, and parameter settings of LLMs used in our study are summarized in Table 1.

Notably, GPT-3.5 and GPT-4 can be accessed through both API and the ChatGPT platform. During our preliminary exploration stage, we compared the performances of GPT-4 and GPT-3.5 accessed through these two ways. The two models provided by the ChatGPT platform performed better and were thus employed in our study. As the default



**Table 1**

Versions and hyper-parameters of 6 LLMs studied.

| Model       | Version            | Context Window | Parameter   |       |                                           |
|-------------|--------------------|----------------|-------------|-------|-------------------------------------------|
|             |                    |                | temperature | top_p | Other parameters                          |
| GPT-3.5     | May 2024 version   | -              |             |       | -                                         |
| GPT-4       | May 2024 version   | -              |             |       | -                                         |
| GPT-4 Turbo | gpt-4-1106-preview | 128k           | 1.0         | 1.0   | max_tokens: 4096; frequency_penalty: 0.0; |
| Gemini Pro  | gemini-1.0-pro     | 32k            | 0.9         | 1.0   | maxOutputTokens: 2048;                    |
| Llama 2 7B  | llama-2-7b-chat    | 4k             | 1.0         | 0.9   | max_seq_len: 4096;                        |
| Llama 2 70B | llama-2-70b-chat   | 4k             | 1.0         | 0.9   | max_seq_len: 4096;                        |
| DeepSeek-R1 | deepseek-r1-250528 | 128k           | 1.0         | 0.7   | max_tokens: 4096; frequency_penalty: 0.0; |

parameters of the employed GPT-4 and GPT-3.5 were not publicly disclosed, the corresponding entries in Table 1 are indicated with ‘-’.

### 2.3.2. Prompt Design

Prompt engineering is a process of designing prompts to optimize model performance on downstream tasks (Liu et al., 2023). To design prompts, we followed the best practices published by OpenAI (OpenAI, 2023) and the three prompt design strategies in Zhang et al. (2024): basic prompt, enhanced prompt with auxiliary information, and CoT prompt. During our preliminary exploration stage, we tried prompts with various auxiliary information and different CoT intermediate reasoning steps. To fully harness the capabilities of LLMs in detecting security defects, we finally selected the five best-performing prompts. Fig. 4 illustrates the construction strategies for the five prompts.

- **Prompt 1 ( $P_b$ ): the basic prompt.** We instruct the LLM to review the provided code for security defects and output their description, code line numbers, and suggested fix. If no defects are found, the LLM should output a fixed sentence, ‘No security defects are detected in the code.’. It is worth noting that we instruct the model to generate a solution for each identified security defect, since an incorrectly detected security defect usually cannot lead to a logically consistent fix in the source code. This process naturally drives the model to evaluate the validity of its detection and acts as an implicit self-reflection mechanism.
- **Prompt 2 ( $P_r$ ):  $P_b$  + Project Information.**  $P_r$  is designed based on  $P_b$  but includes the name of the source project as auxiliary information. The LLM is asked to act as a code reviewer for the project using the provided code in the prompt.
- **Prompt 3 ( $P_c$ ):  $P_b$  + General CWE Instruction.**  $P_c$  directly instructs the LLM to use CWE as a reference for identifying security defects without providing specific CWE details.
- **Prompt 4 ( $P_{cid}$ ):  $P_b$  + Specific CWE Instruction.**  $P_{cid}$  provides a specific list of the first level CWEs in VIEW-1000 (Research Concepts)<sup>1</sup>. We acknowledge that providing a list of CWEs may limit the scope of detection set of

<sup>1</sup>VIEW-1000 is a weaknesses classification framework designed for academic research, widely adopted in prior work (e.g., (Pan et al., 2023)). It organizes CWEs into a hierarchical structure based on parent-child relationships among CWE entries. The first level of CWEs in VIEW-1000 encompasses a broad range of commonly encountered security defects, thus applied in Prompt 4 ( $P_{cid}$ )

CWEs and miss security defects that do not fall into the provided CWE categories. However, including all CWEs is infeasible due to the limited context window of the LLM and the potential loss of focus.

- **Prompt 5 ( $P_{cot}$ ):  $P_{cot-1}$  +  $P_{cot-2}$ .** Since we only included the code of a single file in the prompt instead of an entire patchset, we designed  $P_{cot}$  to analyze the impact of missing contextual information on the performance of LLMs. The task of security code review is split into two steps. In  $P_{cot-1}$ , given that we only provide a single code file from a complete project in the prompt, we include the corresponding commit message of the file and instruct the LLM to generate code context according to the commit message. Then  $P_{cot-2}$  guides the LLM to review the provided code for security defects with reference to the generated code context.

However, in the two-stage  $P_{cot}$ , the performance of LLM can be influenced by three factors: the commit message, CoT guidance, and the code context generated by LLM. Among these, the fabricated code context may contradict the actual code, leading to incorrect judgments. To isolate the impact of the LLM-generated context, we proposed a guardrail version of the  $P_{cot}$  prompt and conducted experiments exclusively on DeepSeek-R1 under this additional prompt.

- **Prompt 6 ( $P_{cot-guardrail}$ ):** This prompt retains the commit message and CoT instruction but does not use the code context generated by LLM, allowing us to evaluate the effect of fabricated contexts. The detailed template is shown in Fig 5.

### 2.3.3. Evaluation Metrics

During the experiments, the responses of LLMs were provided in the form of natural language text, making it necessary to manually inspect these responses to ensure the accuracy of the performance measurements. We considered that LLM-generated responses could be evaluated in a manner similar to the approach adopted by Mahajan et al. (2020) for measuring responses in Stack Overflow. We adapted the evaluation metrics formulated in their work (Mahajan et al., 2020) as follows: First, we excluded the ‘Unavailable’ category defined by Mahajan et al. (2020) because LLMs do not have a case of no response. Next, the definitions of each category were adjusted to match the task of security code review. Specifically, each response was categorized into one of the four rating categories (Instrumental, Helpful,

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>Prompt 1 (<math>P_b</math>):</b> the basic prompt</p> <p>Please review the code below to detect security defects. If any are found, please describe the security defect in detail and indicate the corresponding line number of code and solution. If none are found, state: `No security defects are detected in the code`.</p> <div>original code</div>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <p><b>Prompt 2 (<math>P_r</math>):</b> <math>P_b</math> + Project Information</p> <p>I want you to act as a code reviewer of <span>PROJECT</span> in <span>COMMUNITY</span>. Please review the code below to detect security defects. If any are found, please describe the security defect in detail and indicate the corresponding line number of code and solution. If none are found, state: `No security defects are detected in the code`.</p> <div>original code</div>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <p><b>Prompt 3 (<math>P_c</math>):</b> <math>P_b</math> + General CWE Instruction</p> <p>Please review the code below for security defects using the CWE (Common Weakness Enumeration) as a reference. If any are found, please describe the security defect in detail and indicate the corresponding line number of code and solution. If none are found, state: `No security defects are detected in the code`.</p> <div>original code</div>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <p><b>Prompt 4 (<math>P_{cid}</math>):</b> <math>P_b</math> + Specific CWE Instruction</p> <p>Please review the code below for security defects. You can consider defect types in terms of:</p> <ul style="list-style-type: none"> <li>• CWE-284 (Improper Access Control)</li> <li>• CWE-435 (Improper Interaction Between Multiple Entities)</li> <li>• CWE-664 (Improper Control of a Resource Through its Lifetime)</li> <li>• CWE-682 (Incorrect Calculation)</li> <li>• CWE-691 (Insufficient Control Flow Management)</li> <li>• CWE-693 (Protection Mechanism Failure)</li> <li>• CWE-697 (Insufficient Comparison)</li> <li>• CWE-703 (Improper Check or Handling of Exceptional Conditions)</li> <li>• CWE-707 (Improper Neutralization)</li> <li>• CWE-710 (Improper Adherence to Coding Standards)</li> </ul> <p>If any are found, please describe the security defect in detail and indicate the corresponding line number of code and solution. If none are found, state: `No security defects are detected in the code`.</p> <div>original code</div> |
| <p><b>Prompt 5 (<math>P_{cot}</math>):</b> <math>P_{cot-1}</math> + <math>P_{cot-2}</math></p> <p><b><math>P_{cot-1}</math>:</b> Based on the given code from a commit, please generate supplementary code files according to the commit message.</p> <p>####commit message</p> <div>COMMIT MESSAGE</div> <p>####code</p> <div>original code</div> <p><b><math>P_{cot-2}</math>:</b> In the context of the generated files, analyze the original code for security defects. If any are found, please describe the security defect in detail and indicate the corresponding line number of code and solution. If none are detected, state: `No security defects are detected in the code`.</p>                                                                                                                                                                                                                                                                                                                                                                        |

Figure 4: Construction templates for the five prompts

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>Prompt 6 (<math>P_{cot-guardrail}</math>):</b> the guardrail version of <math>P_{cot}</math></p> <p>You are given code from a commit, along with its commit message.</p> <p>Please review the code below to detect security defects. If any are found, please describe the security defect in detail and indicate the corresponding line number of code and solution. If none are found, state: `No security defects are detected in the code`.</p> <p>You should think step-by-step and then provide the final answer.</p> <p>####commit message</p> <div>COMMIT MESSAGE</div> <p>####code</p> <div>original code</div> |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

 Figure 5: Construction template for the guardrail version of  $P_{cot}$

Misleading, Uncertain). To ensure clearer differentiation, for the ‘Helpful’ and ‘Instrumental’ categories, we specified their definitions based on their performance across three key attributes: defect type, location, and description. The detailed definition and corresponding examples of these four rating categories are as follows:

**Instrumental (I):** The type of the security defect identified in the response is exactly the same as the target security defect, the location is strictly within the code line range of the target security defect, and the defect description can provide effective information for understanding the scenario.

#### Example 1 - Instrumental

**Reviewer:** (Line 76) I think this is race-y. Let’s say we have a three coroutines scheduled to call function. the first may yield at L74, the second enters before the threshold and sleeps at L70 while setting is\_deferred, then the first finishes and unsets at L76, allowing the third to enter before the threshold as well. Then both, second and third coroutines call function in very short time difference.

**LLM:** Race condition in ‘Throttler.call()’(Lines 58-77):  
- The is\_deferred flag is used to determine if a function should be deferred. However, multiple threads can check the is\_deferred flag almost simultaneously and hence more than one thread might execute the contained code.

**Explanation:** LLM indicated the race condition defect identified by the reviewer, with the accurate code line range and detailed description, thus categorized as **Instrumental**.

**Helpful (H):** The type or location of the identified security defect differ to some extent from the target security defect, or the description may be too broad or partially inaccurate. However, the response still provides useful evidence pointing toward the existence of the target defect.

#### Example 2 - Helpful

**Reviewer:** (Line 141) If connect\_info ever includes a secret of a type other than token (e.g. password) that mask\_password looks for, you’d be replacing that with the masked token instead of masking the password or whatever it is. But I guess that’s unlikely.

**LLM:** Potential Information Disclosure (Line 141):  
- Logging connection information can potentially expose sensitive details. Even though ‘mask\_password’ is being used, it’s essential to validate that no other sensitive information is leaked.

**Explanation:** The reviewer noted that the mask\_password function might incorrectly replace different types of sensitive information. While the LLM correctly identified the relevant, it only provided general emphasis on checks for potential sensitive information exposure, failing to recognize this specific risk scenario. So this instance was categorized as **Helpful** rather than **Instrumental**.

**Misleading (M):** The response does not provide any helpful information, e.g., claiming no defects were found or failing to perform the detection task.

#### Example 3 - Misleading

**Reviewer:** (Line 329) This does implicit format detection on the imported disk, which is a well-known security hole. In this specific case a malicious user could create a ‘raw’ image which actually contained a malicious qcow2 header specifying a backing file of the the compute host’s root disk. This would result in copying the compute host’s root disk to the specified rbd volume and exposing it to the user.

**LLM:** Based on the provided code snippet, no security defects are detected. For a more comprehensive analysis, a full code audit in the context of the entire application and its environment would be recommended.

**Explanation:** The reviewer pointed out a sensitive data exposure at line 329, whereas the LLM did not detect any security defects. Therefore, it was classified as **Misleading**.

**Uncertain (U):** The response does not mention any defects identified by the reviewer but instead points out the existence of other security defects. Due to the lack of expertise of the researchers about the code and its context, the actual existence of these security defects cannot be confirmed.

#### Example 4 - Uncertain

**Reviewer:** (Line 469) So not even timeout cancels the future? Will this cause that threads will hang around forever leaking OS resources? This feels dangerous.

**LLM:** \*\*Potential Insecure Direct Object References (Lines 89-563):\*\*

- The ‘RequestContext’ class and its methods provide direct access to project and user identifiers, and various methods in this file allow direct manipulation of database and message queue connections. If access controls are not properly enforced or if input validation is weak, this could lead to unauthorized access or manipulation of data.

**Explanation:** The reviewer identified that the thread handling may lead to OS resource leaks. However, LLM did not mention any about resource leak, instead highlighting a potential improper access issue. Since access mechanisms might be uniformly managed by a middleware, and considering the unavailability of detailed implementation information, we cannot determine whether the issue pointed out by LLM exists. Thus this instance was categorized as **Uncertain**.

The corresponding evaluation metrics are I-Score ( $\frac{I}{I+H+U+M} \times 100\%$ ), IH-Score ( $\frac{I+H}{I+H+U+M} \times 100\%$ ), and M-Score ( $\frac{M}{I+H+U+M} \times 100\%$ ). Higher I-Score and IH-Score indicate a stronger ability of the model to detect security defects identified by reviewers. At the same time, a lower

M-Score signifies fewer misleading results produced during security defect detection. Given that LLMs exhibit considerable non-determinism, we repeated the experiment for each LLM-prompt combination three times and calculated the average of the three performance scores as the final result, so as to alleviate this threat and ensure a reliable evaluation of LLMs' capabilities in security defect detection.

It is important to note that the cost and latency of LLMs in security code review are significant concerns for practitioners. However, in this study, these two points were not specifically discussed. Due to the various invocation methods of the LLMs involved (including calls through the ChatGPT platform, local deployment, and API calls), it is difficult to provide a consistent cost estimate across different LLMs. Moreover, the latency of the models is significantly affected by their deployment environments, such as computational resources, inference engines, and parallelization strategies, making the latency of different LLMs in our experiments incomparable.

### 2.3.4. Baselines

We tried different tools and learning techniques for detecting security defects to select appropriate baselines for our work. To compare with LLMs, we focused on techniques providing fine-grained detection, including classification, localization, and description of defects. This led us to exclude techniques with insufficient detection granularity, such as ProRLearn (Ren et al., 2024), GRACE (Lu et al., 2024) and LineVul (Fu and Tantithamthavorn, 2022). Given that we evaluated the performance of LLMs on the C/C++ and Python datasets separately, for language-specific static analysis tools, we selected CppCheck (Marjamäki et al., 2024) for C/C++ and Bandit (PyCQA, 2024) for Python. Furthermore, we also used CodeQL (GitHub, 2021) and SonarQube (SA, 2024) to analyze Python files. These two tools can directly analyze code files written in dynamically-typed languages like Python but require code files in statically-typed languages like C/C++ to be compiled first. Therefore, we could not apply them to our C/C++ dataset, which is comprised of uncompiled and isolated C/C++ code files. Additionally, since Semgrep (Dennison et al., 2024) supports multiple programming languages and can analyze individual code files, we adopted it for both C/C++ and Python datasets. To obtain comprehensive analysis results, CodeQL adopted the Python-security-and-quality.qls test suite, covering a wide range of issues from basic code structure and naming conventions to advanced security and performance vulnerabilities. Other tools utilized their default rule sets for analysis.

### 2.3.5. Data Labelling

Prompts were constructed using five templates and then fed into seven LLMs to collect their responses. Since the responses of LLMs were provided in the form of natural language text, to rate the responses accurately, we manually inspected the content of LLM-generated responses, their corresponding source code, and security defects identified by

reviewers to categorize them into the four categories defined in Section 2.3.3. To mitigate bias, pilot data labelling was conducted, in which we randomly selected 100 out of 534 code files from our dataset, constructed five prompts for each file and fed these prompts into LLMs to collect responses. Using the definitions of the four categories as labelling criteria, the first and third authors labelled the collected responses separately. Discrepancies in labelling results were discussed with the second author to reach a consensus. The inter-rater reliability was calculated using Cohen's Kappa coefficient (Cohen, 1960), yielding a value of 0.89. Then, the first and third authors labelled all the rest of the responses and discussed any ambiguous cases with the second author to finalize the categorization. For the additional experiments on the combination of  $P_{cot-guardrail}$  and DeepSeek-R1, we applied the same labelling approach. Based on the labelling results, we calculated the performance scores of each LLM-prompt combination in the Python and C/C++ datasets. We found that the best-performing LLM is DeepSeek-R1, followed by GPT-4. On the complete dataset (including both Python and C/C++ files), the optimal prompts for DeepSeek-R1 and GPT-4 are  $P_{cot-guardrail}$  and  $P_{cid}$ , respectively, as detailed in Section 3.1. Therefore, for further analysis of RQ2 and RQ3, we selected the responses generated by *DeepSeek-R1* +  $P_{cot-guardrail}$  and *GPT-4* +  $P_{cid}$  across three repetitive experiments. Since some code files exceeded the token limit, we ultimately obtained 1509 responses for DeepSeek-R1 and 1263 responses for GPT-4.

### 2.3.6. Consistency Calculation

To measure the non-determinism of LLMs, we adopted the metrics in Chang et al. (2024) and utilized entropy to measure the consistency of responses generated by LLMs across three repetitive experiments. Specifically, an LLM generated three responses for a given code file under a specific prompt template. We then calculated the entropy for the four response categories in the three responses. We determined the overall consistency by averaging the entropy across all code files using the following formula:  $\frac{1}{R} \sum_{r \in R} \text{entropy}(p'_1, \dots, p'_4)$ , where  $R$  is the response count in each round of the experiment. A higher mean entropy suggests the LLM has higher inconsistency in repetitions of experiments. To further quantify the uncertainty of the entropy estimates and ensure the reliability of our findings, bootstrap confidence intervals were calculated for each LLM-prompt combination. Following the guidance of Efron and Tibshirani (1994), we resampled the original dataset with replacement to match its original size and calculated the mean entropy for each resample. As suggested by Davison and Hinkley (1997), if confidence levels 0.95 and 0.99 are to be used, then it is advisable to have [the number of resamples]=999 or more, if practically feasible. Therefore, consistent with the settings adopted in Ahmed et al. (2025), we performed 1,000 bootstrap replications to obtain the 95% confidence intervals for the entropy estimates.



## 2.4. Research Procedure of RQ2

We manually inspected the responses of *DeepSeek-R1+P<sub>cot-guardrail</sub>* and *GPT-4+P<sub>cid</sub>* across the three repetitive experiments to analyze the quality problems present in these responses. We employed the open coding and constant comparison (Glaser, 1965) with a predefined category by the MAXQDA tool for qualitatively analyzing the responses.

Based on the problem categories formulated by Kabir et al. (2024) and the problems of LLM-generated text in various domains identified by previous studies (Borji, 2023; Mitrović et al., 2023; Kalla and Kuraku, 2023), two of the authors firstly inspected a few responses independently and recorded their observations. Then they collaboratively reviewed the inspected responses and discussed to establish an initial codebook, resulting in four themes: **Correctness**, **Understandability**, **Conciseness**, and **Compliance**, each with a series of problem types. In particular, we excluded the *Consistency* theme defined in Kabir et al. (2024) from our study. The reason is that the consistency between the LLM's responses and the reviewers' assessments (i.e., the ground truth) has been investigated in RQ1. Following the codebook, we conducted a pilot data analysis across two iterations to improve the agreement between the two authors. In each round, ten responses were randomly selected for the two authors to analyze their quality problems. The results were then compared and discussed, with partial adjustments made to the codebook. Since a single response could contain multiple problems, two authors completed the remaining data analysis task where the labels are not mutually exclusive. Therefore, we calculated the agreement level using Krippendorff's alpha (Krippendorff, 2004) with Jaccard distance, which was improved from 0.40 in the first round to 0.80 in the second, indicating a high level of agreement. Then the two authors completed the remaining data analysis and verified by the second author. Throughout the entire procedure, we employed a negotiated agreement approach (Campbell et al., 2013): any conflicts were consulted and addressed by three authors, ensuring the reliability of data analysis. For each quality problem type, we computed the average frequency across three repetitive experiments of two LLM+prompt combinations (*DeepSeek-R1+P<sub>cot-guardrail</sub>* and *GPT-4+P<sub>cid</sub>*), as the final occurrence rate of this problem in the responses of each combination.

We consider the finalized codebook to cover all types of quality problems present in the LLM-generated responses within our dataset. To further analyze the proportion of hallucinations in LLMs' responses, we adopted the granular taxonomy proposed by Huang et al. (2025), which categorizes hallucinations into two main types: Factual and Faithfulness. **Factual Hallucination** refers to outputs that contradict real-world facts or lack factual grounding, including *Factual Contradiction* and *Factual Fabrication*. **Faithfulness hallucination**, on the other hand, refers to deviations of the output from the instruction, current context, and reasoning process, including *Instruction Inconsistency*, *Context Inconsistency*, and *Logical Inconsistency*. We mapped the quality problems defined in our codebook to

these hallucination subtypes to calculate their distribution across the dataset. Detailed mapping and results are provided in Section 3.2.

## 2.5. Research Procedure of RQ3

To answer RQ3, we adopted the approach formulated by Harrell (Harrell, 2001) to construct a regression model. As mentioned in Section 2.3.3, the response variables in our dataset are the ratings of I, H, U, and M. In terms of the helpfulness of the response, by definition, I is more important than H, and so forth. Accounting for the ordinal nature of the response variable and the non-determinism of the LLM in three rounds of experiments, we ultimately aggregated the data from all three experiments to fit a cumulative link mixed model (Powers and Xie, 2008). This model supports ordered categorical response variables and allows us to include random effects to group responses in each round together. The specific construction process is described in the following subsections.

### 2.5.1. Attributes Construction

To comprehensively collect factors influencing the detection of security defects by LLMs, excluding the prompt and the model itself, we undertook the following steps:

First, we **collected** the attributes from previous works (Paul et al., 2021; McIntosh et al., 2016; Thongtanunam et al., 2017) that were utilized in analyzing relationships related to code review and applicable to the code file data in our work. Given that LLMs understand and generate text token by token, we **adjusted** the factor adopted from McIntosh et al. (2016) — 'Size', to 'Token' (see the first row of Table 2), as larger code files typically contain more tokens. Next, we extracted characteristics of data that were explicitly indicated to affect or correlate with the capabilities of LLMs in Chen et al. (2023); Sovrano et al. (2025), **transforming** them into factors for our experiment. Lastly, after thoroughly observing and analyzing the distribution of responses, we further **created** and adopted several potentially influential factors based on our observations. In the end, we obtained a list of 11 factors in Table 2, along with the source, definition, and rationale for each factor.

Since acquiring a factor like 'AuthorExperience' entails querying the code review history of projects, we utilized Gerrit API to retrieve detailed information for all patchsets under each code change. We used Python scripts complemented with manual analysis to query, compute, and label these factors. We aggregated the dataset from three repetitive experiments, yielding 1,263 responses from *GPT-4+P<sub>cid</sub>* and 1,509 responses from *DeepSeek-R1+P<sub>cot-guardrail</sub>*. Each experiment contributed 421 and 503 responses, respectively, with their factor values ready for model fitting.

### 2.5.2. Regression Model Construction

**Correlation and Redundancy Analysis:** If explanatory variables are highly correlated, it can cause interference

**Table 2**

Factors that may influence the performance of LLM in security code review

| Factor                      | Source*                                                   | Definition                                                                                                                                                                                                                                                                              | Rationale                                                                                                                                                                                                                                                      |
|-----------------------------|-----------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Token                       | Adjusted from Paul et al. (2021); McIntosh et al. (2016)  | Number of tokens of the code file. Computed using the TikToken OpenAI (2024) tokenizer.                                                                                                                                                                                                 | Larger code files may be more difficult for LLMs to analyze.                                                                                                                                                                                                   |
| Position                    | Collected from Sovrano et al. (2025)                      | Position of the security defect within the code file. Determined by calculating the proportion of tokens preceding the defect relative to the total token count, using the TikToken OpenAI (2024) tokenizer.                                                                            | LLMs tend to significantly underperform when detecting security defects located toward the end of files (Sovrano et al., 2025; Rafi et al., 2024).                                                                                                             |
| FileType                    | Created                                                   | Type of the code file, i.e., <i>Source</i> or <i>Auxiliary</i> . <i>Source</i> indicates files that directly contain the logic of the application (i.e., .cpp, .c and .py) while <i>Auxiliary</i> files are utilized for declarations (i.e., .h and .hpp).                              | The understanding capability of LLMs and the scenarios of security defects may vary across different types of files.                                                                                                                                           |
| SecurityDefectType          | Transformed from Chen et al. (2023)                       | Type of the security defect that the reviewers identified in this code file, i.e., one of the 15 types of security defect formulated by Yu et al. (2023).                                                                                                                               | ChatGPT is proven to display distinct detection performances across various vulnerabilities Chen et al. (2023); Zhou et al. (2023). Thus, we assume that LLMs may be more adept at detecting certain specific types of security defects in code.               |
| Commit                      | Collected from Paul et al. (2021)                         | Number of historical commits for the code file in its code change.                                                                                                                                                                                                                      | Excessive history commits may lead developers to fatigue or overconfidence, resulting in their ignorance of security considerations in simpler scenarios.                                                                                                      |
| Complexity                  | Collected from Paul et al. (2021); McIntosh et al. (2016) | McCabe's Cyclomatic Complexity McCabe (1976). Computed using the Lizard Terry (2024) analyzer.                                                                                                                                                                                          | Code comprehensibility may become more challenging for LLMs as its cyclomatic complexity increases Paul et al. (2021).                                                                                                                                         |
| Community                   | Created                                                   | Name of the community source of the code file, i.e., <i>OpenStack</i> or <i>Qt</i> .                                                                                                                                                                                                    | OpenStack and Qt differ significantly in terms of their structure, technology stack, project function, and main components. The LLMs' performance may differ on data derived from these two communities.                                                       |
| AuthorExperience            | Collected from Paul et al. (2021)                         | Number of closed code commits the author has submitted prior to the commit this code file corresponding to.                                                                                                                                                                             | Experienced authors may write more rigorous and standardized code, while the security vulnerabilities in the code are also relatively more subtle and difficult to detect.                                                                                     |
| AnnotationRatio             | Created                                                   | The ratio of manual annotations in the code file. If the token number of all annotations in the file $f$ is $a$ , and the total token number of this file is $f_t$ , then $AR = a/f_t$ .                                                                                                | The capability of LLMs to comprehend manual annotations and code may vary.                                                                                                                                                                                     |
| AnnotationHasCode           | Transformed from Chen et al. (2023)                       | Whether the annotations in the code file include code.                                                                                                                                                                                                                                  | Code in annotations was abandoned by developers but often interpreted as actual code by LLMs Chen et al. (2023), leading to incorrect security defect detection.                                                                                               |
| AnnotationisSecurityRelated | Created                                                   | The relevance of annotations to the security defects identified by reviewers in this code file, i.e., 1 (annotations mentioned target security defects identified by reviewers), 0 (Annotations were unrelated to security) and -1 (Annotations mentioned non-target security defects). | Keywords in the description related to target security defect in annotations can act as cues for LLMs, while the descriptions of non-target security defects often involve the historical fixing or security mechanisms, which may cause interference to LLMs. |

\* The sources of factors correspond to the descriptions in **bold** in Section 2.5.1.

in model construction and analysis. As the predefined explanatory variables in our study include both categorical and continuous variables, we utilized a refined Pearson's hypothesis test of independence — Phi\_K (Baak et al., 2020), to measure the correlation between each factor. The correlation coefficients obtained are illustrated in Fig. 6. We chose  $|\rho| > 0.7$  as the threshold because it is recommended as the threshold for strong correlation (Hinkle et al., 2003). From Fig. 6, where an abbreviation denotes each factor, it can be seen that the correlation coefficients between each pair of factors are all below 0.7, suggesting that there is no strong correlation between these factors. However, two factors without high correlation can still be duplicates, distorting the relationship between explanatory and response variables in model fitting. We encoded categorical variables as dummy variables for redundancy analysis (Legendre and Legendre, 2012). Utilizing the *redun* function in the *rms*

package<sup>2</sup>, we assessed potential redundant variables with its default threshold of  $R^2 \geq 0.9$ , ultimately finding none.

**Degrees of Freedom Allocation:** To assign degrees of freedom to each explanatory variable, we measured the potential of nonlinear relationships between each factor and the response variable by calculating Spearman's rank correlations ( $\rho^2$ ) between them. As Harrell (2001) recommended, explanatory variables with larger  $\rho^2$  can be assigned higher degrees of freedom. Paul et al. (2021) suggested limiting the maximum allocated degrees of freedom for an explanatory variable to five or fewer, thus reducing the risk of overfitting. According to the computation results shown in Fig. 7, for interval variables, we considered using the *rcs* function from the R's *rms* package to allocate 3 degrees of freedom for the factor 'Token' with the highest  $\rho^2$ , while the other factors are allocated 1 degree of freedom. Category variables should be converted into factor variables, and their corresponding

<sup>2</sup><https://cran.r-project.org/web/packages/rms/index.html>



**Figure 6:** The  $\Phi_K$  correlation coefficients of explanatory variables

degrees of freedom are automatically allocated during model fitting.

**Model Fitting:** Next, we fitted the responses of *GPT-4*+ $P_{cid}$  and *DeepSeek-R1*+ $P_{cot-guardrail}$ , along with their rating categories onto two separate cumulative link mixed model using the *clmm* function from the *ordinal* R package (Christensen and Christensen, 2015). We tested models with and without allocating 3 degrees of freedom to the ‘Token’ factor to balance model complexity and fit. Finally, for *GPT-4*+ $P_{cid}$ , we selected the model that did not allocate the additional degrees of freedom, while for *DeepSeek-R1*+ $P_{cot-guardrail}$ , we chose the model with the added degrees of freedom, as each exhibited a lower Akaike Information Criterion (AIC) for their respective Fittings (Burnham and Anderson, 2004).

All the results and scripts utilized in data labelling, extraction, and regression analysis are provided in our replication package (Yu et al., 2025).

### 3. Results

#### 3.1. Performance of LLMs (RQ1)

Based on the evaluation metrics defined in Section 2.3.3, we evaluated the capability of six popular LLMs in security code review across different prompts. We compared the performance of LLMs with baseline tools in the C/C++ and Python datasets, respectively. If two of the three metrics were superior (i.e., higher I-Score or IH-Score, lower M-Score), we deemed that the current combination outperformed the others. Due to differences in the token limit of each LLM and the inherent token count of each prompt template, the number of responses successfully generated by each LLM-prompt combination also varied. To avoid bias due to different samples and to ensure rigorous comparisons, we also performed analysis on the intersection of source code files that all LLM-prompt combinations could generate

responses, which yielded 57 instances. As a result, two sets of scores are provided: (1) the response count and performance scores of each LLM-prompt combination on the complete Python and C/C++ dataset (see Table 3 and Table 4), and (2) the performance scores of each LLM-prompt combination on the selected 57 instances (see Table 5). The best values for each score are highlighted in bold and marked with asterisks in the tables. It is evident that, DeepSeek-R1 outperformed all other models, followed by GPT-4. Specifically, Table 3 shows that on the Python dataset, the combination of DeepSeek-R1 with  $P_{cid}$  achieved the best performance. According to Table 4, on the C/C++ dataset, the combination of DeepSeek-R1 with  $P_{cot-guardrail}$  performed the best. Furthermore, Table 5 demonstrates that in the selected 57 cases, DeepSeek-R1 with  $P_b$  achieved better results than all other LLM-prompt combinations. Although GPT-4 did not perform as well as DeepSeek-R1, it still obviously surpassed the remaining five LLMs. For the top two models, DeepSeek-R1 and GPT-4, we calculated the performance scores of these two models across different prompt templates on the full dataset (including both Python and C/C++ datasets), as shown in Table 6. We found that DeepSeek-R1 performed best with  $P_{cot-guardrail}$ , whereas GPT-4 achieved its highest scores with  $P_{cid}$ . On the whole, as of the time of our experiment (May 2024), the capabilities of currently popular LLMs in conducting security code reviews are still limited. Notably, with enhanced prompts, the best performance of each LLM in security code review is significantly superior to that of static analysis tools. This could be attributed to two reasons: (1) for context-sensitive tools such as CodeQL, static analysis can be impacted by the lack of code context in our dataset (Russo and Sabelfeld, 2010); (2) there is a relatively high frequency of security defects related to multi-threading and asynchronous programming, such as *race conditions*. As such, features can only be accurately modelled using dynamic analysis, and these security defects are challenging for static analysis tools to detect (Charoenwet et al., 2024).

##### 3.1.1. RQ1.1

When using basic prompts constructed by  $P_b$  (see Table 3 and Table 4), DeepSeek-R1 performed the best, obtaining the highest I-Score (Python: 5.41%, C/C++: 12.64%), and the lowest M-Score (Python: 36.04%, C/C++: 29.99%). For the IH-Score, DeepSeek-R1 still achieved the highest value on the C/C++ dataset, reaching 15.49%, while on the Python dataset, GPT-4 outperformed DeepSeek-R1 (7.83%) with a score of 9.34%. GPT-4 was regarded as the second-best model, followed by Llama 2 70B and GPT-3.5. GPT-4 Turbo, Gemini Pro, and Llama 2 7B performed the worst, with their performance in the Python dataset even inferior to that of the baseline tool, Bandit. Similar results are observed in Table 5. Specifically, in the selected 57 instances, under the basic prompt  $P_b$ , DeepSeek-R1 achieved I-Score = 16.96%, IH-Score = 23.98%, and M-Score = 40.35%. It is evident that DeepSeek-R1’s performance on the selected 57 instances exceeds its performance across the entire dataset. Given that these 57 code files are instances with relatively

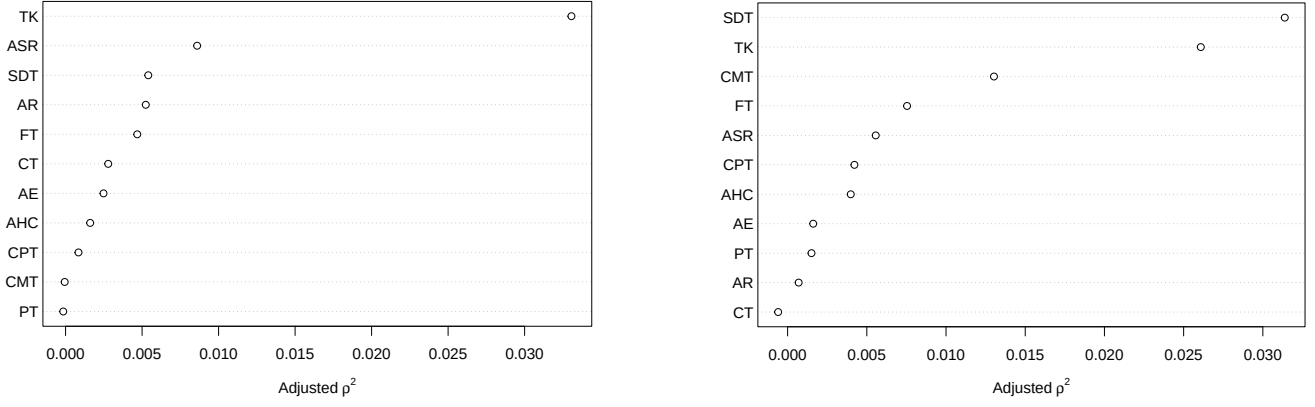


Figure 7: Dotplot of the Spearman  $\rho^2$  between explanatory and response variables across three repetitive experiments

Table 3

Performance scores and entropy for each LLM-Prompt combination on the Python dataset

|                |             | Python    |        |         |           |           |                     |
|----------------|-------------|-----------|--------|---------|-----------|-----------|---------------------|
| Model & Prompt |             | $P_b$     | $P_r$  | $P_c$   | $P_{cid}$ | $P_{cot}$ | $P_{cot-guardrail}$ |
| GPT-3.5        | Resp. Count | 123       | 123    | 123     | 123       | 122       |                     |
|                | I-Score     | 1.08%     | 1.35%  | 0.27%   | 0.27%     | 1.37%     |                     |
|                | IH-Score    | 2.71%     | 3.80%  | 1.35%   | 0.27%     | 5.19%     |                     |
|                | M-Score     | 89.37%    | 84.28% | 92.41%  | 97.29%    | 69.12%    |                     |
|                | Entropy     | 0.2572    | 0.3692 | 0.2070  | 0.0746    | 0.6842    |                     |
| GPT-4          | Resp. Count | 175       | 175    | 175     | 174       | 174       |                     |
|                | I-Score     | 4.76%     | 3.43%  | 3.24%   | 5.17%     | 3.06%     |                     |
|                | IH-Score    | 9.34%     | 9.52%  | 8.38%   | 14.56%*   | 8.62%     |                     |
|                | M-Score     | 61.31%    | 60.95% | 46.47%  | 44.06%    | 61.69%    |                     |
|                | Entropy     | 0.7426    | 0.7283 | 0.8600  | 0.9416    | 0.7450    |                     |
| GPT-4 Turbo    | Resp. Count | 201       | 201    | 201     | 201       | 201       |                     |
|                | I-Score     | 0.66%     | 1.65%  | 0.66    | 0.83      | 0.17      |                     |
|                | IH-Score    | 0.66      | 0.83   | 2.32    | 1.99      | 0.33      |                     |
|                | M-Score     | 97.18%    | 96.35% | 85.74%  | 92.87%    | 98.01%    |                     |
|                | Entropy     | 0.0777    | 0.0901 | 0.2424  | 0.1873    | 0.0548    |                     |
| Gemini Pro     | Resp. Count | 162       | 161    | 160     | 160       | 159       |                     |
|                | I-Score     | 0.00%     | 0.00%  | 0.63%   | 1.25%     | 0.21%     |                     |
|                | IH-Score    | 0.41%     | 0.00%  | 0.84%   | 3.54%     | 0.21%     |                     |
|                | M-Score     | 90.54%    | 97.09% | 84.04%  | 55.21%    | 98.53%    |                     |
|                | Entropy     | 0.1757    | 0.0746 | 0.3370  | 0.6125    | 0.0404*   |                     |
| Llama 2 7B     | Resp. Count | 62        | 62     | 61      | 61        | 50        |                     |
|                | I-Score     | 0.00%     | 0.54%  | 1.62%   | 2.19%     | 1.33      |                     |
|                | IH-Score    | 1.61%     | 1.61%  | 5.40%   | 8.74%     | 4.67%     |                     |
|                | M-Score     | 87.10%    | 83.33% | 56.78%  | 40.98%    | 33.33%    |                     |
|                | Entropy     | 0.2625    | 0.3070 | 0.4766  | 0.4351    | 0.5521    |                     |
| Llama 2 70B    | Resp. Count | 62        | 62     | 62      | 61        | 47        |                     |
|                | I-Score     | 0.54%     | 1.07%  | 2.15%   | 3.83%     | 1.42%     |                     |
|                | IH-Score    | 4.84%     | 4.30%  | 6.45%   | 11.48%    | 3.55%     |                     |
|                | M-Score     | 79.57%    | 84.41% | 58.60%  | 43.17%    | 36.17%    |                     |
|                | Entropy     | 0.4470    | 0.3474 | 0.3514  | 0.3832    | 0.5762    |                     |
| DeepSeek-R1    | Resp. Count | 234       | 234    | 234     | 234       | 234       | 234                 |
|                | I-Score     | 5.41%     | 6.27%  | 4.70%   | 7.26%*    | 4.56%     | 5.84%               |
|                | IH-Score    | 7.83%     | 7.55%  | 6.27%   | 9.26%     | 6.41%     | 8.69%               |
|                | M-Score     | 36.04%    | 32.05% | 29.34%* | 30.77%    | 46.87%    | 35.69%              |
|                | Entropy     | 0.5440    | 0.5273 | 0.5098  | 0.5444    | 0.5683    | 0.5526              |
| Baselines      | SAST        | SonarQube | CodeQL | Bandit  | Semgrep   |           |                     |
|                | Resp. Count | 258       | 258    | 258     | 258       |           |                     |
|                | I-Score     | 0.00%     | 0.39%  | 0.00%   | 0.00%     |           |                     |
|                | IH-Score    | 0.00%     | 1.16%  | 1.16%   | 0.00%     |           |                     |
|                | M-Score     | 91.47%    | 82.56% | 78.29%  | 90.31%    |           |                     |

fewer tokens within our dataset, it could be speculated that the quantity of tokens input to LLM affects its performance in detecting security defects, which has been further explored and analyzed in RQ3.

### 3.1.2. RQ1.2

$P_r$ : As shown in Table 3 and Table 4, the changes of the performance scores of each LLM under prompt  $P_r$  compared with that under  $P_b$  is generally small. Specifically,

DeepSeek-R1, GPT-3.5, GPT-4, and GPT-4 Turbo show subtle increases and decreases in performance on the Python and C/C++ datasets, respectively. Gemini Pro and Llama 2 70B demonstrate minor performance decreases on both datasets, while Llama 2 7B shows a slight improvement. A possible reason is that the name of components or packages utilized may already imply the source project of the code file, thereby diminishing the impact of project information



Table 4

Performance scores and entropy for each LLM-Prompt combination on the C/C++ dataset

|                |             | C/C++    |         |         |           |           |                     |
|----------------|-------------|----------|---------|---------|-----------|-----------|---------------------|
| Model & Prompt |             | $P_b$    | $P_r$   | $P_c$   | $P_{cid}$ | $P_{cot}$ | $P_{cot-guardrail}$ |
| GPT-3.5        | Resp. Count | 141      | 141     | 141     | 139       | 137       |                     |
|                | I-Score     | 1.89%    | 2.13%   | 0.00%   | 0.24%     | 0.73%     |                     |
|                | IH-Score    | 5.67%    | 3.31%   | 0.47%   | 0.96%     | 1.46%     |                     |
|                | M-Score     | 76.60%   | 86.05%  | 99.29%  | 95.44%    | 84.43%    |                     |
|                | Entropy     | 0.4860   | 0.2439  | 0.0195* | 0.1153    | 0.2931    |                     |
| GPT-4          | Resp. Count | 247      | 247     | 247     | 247       | 247       |                     |
|                | I-Score     | 4.45%    | 3.91%   | 3.91%   | 5.40%     | 5.26%     |                     |
|                | IH-Score    | 7.96%    | 8.01%   | 9.31%   | 11.74%    | 11.47%    |                     |
|                | M-Score     | 55.47%   | 64.24%  | 44.53%  | 39.00%    | 43.59%    |                     |
|                | Entropy     | 0.6215   | 0.5329  | 0.6505  | 0.6955    | 0.7330    |                     |
| GPT-4 Turbo    | Resp. Count | 269      | 269     | 269     | 269       | 269       |                     |
|                | I-Score     | 0.25%    | 0.12%   | 0.25%   | 0.50%     | 0.25%     |                     |
|                | IH-Score    | 0.25%    | 0.37%   | 1.24%   | 1.61%     | 1.12%     |                     |
|                | M-Score     | 98.02%   | 98.64%  | 91.08%  | 93.43%    | 96.28%    |                     |
|                | Entropy     | 0.0512   | 0.0332  | 0.1401  | 0.1576    | 0.1024    |                     |
| Gemini Pro     | Resp. Count | 223      | 221     | 221     | 221       | 220       |                     |
|                | I-Score     | 0.00%    | 0.15%   | 0.30%   | 1.66%     | 0.00%     |                     |
|                | IH-Score    | 0.45%    | 0.15%   | 0.90%   | 3.77%     | 0.45%     |                     |
|                | M-Score     | 92.97%   | 98.19%  | 89.44%  | 61.54%    | 99.09%    |                     |
|                | Entropy     | 0.1430   | 0.0457  | 0.2493  | 0.5413    | 0.0250    |                     |
| Llama 2 7B     | Resp. Count | 57       | 57      | 57      | 51        | 33        |                     |
|                | I-Score     | 0.58%    | 0.00%   | 0.00%   | 2.61%     | 1.01%     |                     |
|                | IH-Score    | 2.34%    | 3.51%   | 5.85%   | 4.58%     | 7.07%     |                     |
|                | M-Score     | 90.06%   | 87.13%  | 81.29%  | 52.94%    | 27.27%    |                     |
|                | Entropy     | 0.2650   | 0.2167  | 0.2167  | 0.4092    | 0.5954    |                     |
| Llama 2 70B    | Resp. Count | 57       | 57      | 57      | 51        | 37        |                     |
|                | I-Score     | 1.17%    | 1.17%   | 1.75%   | 6.54%     | 1.80%     |                     |
|                | IH-Score    | 4.68%    | 2.92%   | 3.51%   | 15.03%    | 6.31%     |                     |
|                | M-Score     | 67.25%   | 80.12%  | 66.08%  | 40.52%    | 54.05%    |                     |
|                | Entropy     | 0.5667   | 0.4145  | 0.3895  | 0.5515    | 0.6153    |                     |
| DeepSeek-R1    | Resp. Count | 269      | 269     | 269     | 269       | 269       | 269                 |
|                | I-Score     | 12.64%   | 8.43%   | 9.91%   | 10.61%    | 9.79%     | 12.89%*             |
|                | IH-Score    | 15.49%*  | 10.41%  | 11.15%  | 12.27%    | 12.64%    | 15.49%*             |
|                | M-Score     | 29.99%   | 20.94%* | 21.93%  | 23.05%    | 34.32%    | 27.39               |
|                | Entropy     | 0.5411   | 0.4934  | 0.4884  | 0.5002    | 0.5654    | 0.5663              |
| Baselines      | SAST        | CppCheck | Semgrep |         |           |           |                     |
|                | Resp. Count | 276      | 276     |         |           |           |                     |
|                | I-Score     | 0.00%    | 0.00%   |         |           |           |                     |
|                | IH-Score    | 0.72%    | 0.36%   |         |           |           |                     |
|                | M-Score     | 98.19%   | 96.74%  |         |           |           |                     |

Table 5

Performance scores for each LLM-Prompt combination on 57 instances that all LLM-prompt combinations could generate responses

| Model & Prompt |          | $P_b$   | $P_r$   | $P_c$  | $P_{cid}$ | $P_{cot}$ | $P_{cot}$ |
|----------------|----------|---------|---------|--------|-----------|-----------|-----------|
| GPT-3.5        | I-Score  | 3.51%   | 3.51%   | 0.58%  | 0.58%     | 2.34%     |           |
|                | IH-Score | 7.60%   | 8.77%   | 1.17%  | 0.58%     | 4.09%     |           |
|                | M-Score  | 81.87%  | 79.53%  | 94.74% | 95.32%    | 77.19%    |           |
| GPT-4          | I-Score  | 8.77%   | 8.77%   | 5.85%  | 12.87%    | 9.94      |           |
|                | IH-Score | 20.46%  | 19.30%  | 14.04% | 23.98%*   | 19.88     |           |
|                | M-Score  | 43.86%  | 42.11%  | 45.61% | 40.35%    | 41.52%    |           |
| GPT-4 Turbo    | I-Score  | 0.58%   | 1.75%   | 2.34%  | 2.34%     | 0.00%     |           |
|                | IH-Score | 0.58%   | 3.51%   | 5.26%  | 4.09%     | 1.75%     |           |
|                | M-Score  | 97.08%  | 91.23%  | 75.44% | 88.30%    | 92.98%    |           |
| Gemini Pro     | I-Score  | 0.58%   | 0.00%   | 0.00%  | 0.58%     | 0.00%     |           |
|                | IH-Score | 1.17%   | 0.00%   | 0.58%  | 2.92%     | 0.00%     |           |
|                | M-Score  | 96.49%  | 100.00% | 88.30% | 76.61%    | 100.00%   |           |
| Llama 2 7B     | I-Score  | 0.58%   | 1.17%   | 1.17%  | 0.58%     | 1.75%     |           |
|                | IH-Score | 1.75%   | 2.34%   | 4.09%  | 2.34%     | 7.60%     |           |
|                | M-Score  | 87.13%  | 84.21%  | 60.82% | 53.80%    | 25.73%    |           |
| Llama 2 70B    | I-Score  | 2.34%   | 1.17%   | 2.92%  | 5.26%     | 4.09%     |           |
|                | IH-Score | 4.68%   | 2.34%   | 7.02%  | 17.54%    | 4.68%     |           |
|                | M-Score  | 70.18%  | 80.12%  | 42.69% | 20.47%*   | 44.44%    |           |
| DeekSeek-R1    | I-Score  | 16.96%* | 16.37%  | 12.87% | 16.37%    | 13.45%    | 12.28%    |
|                | IH-Score | 23.98%* | 19.88%  | 15.79% | 21.64%    | 18.71%    | 18.13%    |
|                | M-Score  | 40.35%  | 37.43%  | 35.67% | 30.99%    | 45.61%    | 32.75%    |

provided in  $P_r$ . Furthermore, the improvement of emphasizing the task through adding a persona in the prompt is LLM-specific. We speculate that some LLMs may already understand the task described in the prompt quite well, and thus,

introducing a persona could add unnecessary complexity to the prompt and lead to distractions.

$P_c$ : We can see from Table 3 and Table 4 that compared to using the basic prompt  $P_b$ , the performance of DeepSeek-R1 and GPT-3.5 significantly decreases under  $P_c$  in both

**Table 6**

Performance scores and entropy for GPT-4 and DeepSeek-R1 under different prompts on the complete dataset

| Model & Prompt |             | $P_b$  | $P_r$  | $P_c$   | $P_{cid}$ | $P_{cot}$ | $P_{cot-guardrail}$ |
|----------------|-------------|--------|--------|---------|-----------|-----------|---------------------|
| GPT-4          | Resp. Count | 422    | 422    | 422     | 421       | 421       |                     |
|                | I-Score     | 4.58%  | 3.71%  | 3.63%   | 5.30%*    | 4.35%     |                     |
|                | IH-Score    | 8.53%  | 8.63%  | 8.92%   | 12.91%*   | 10.29%    |                     |
|                | M-Score     | 57.89% | 62.88% | 45.33%  | 41.09%*   | 51.07%    |                     |
| DeepSeek-R1    | Resp. Count | 503    | 503    | 503     | 503       | 503       | 503                 |
|                | I-Score     | 9.28%  | 7.43%  | 7.49%   | 9.05%     | 7.36%     | 9.61%*              |
|                | IH-Score    | 11.93% | 9.08%  | 8.88%   | 10.87%    | 9.74%     | 12.33%*             |
|                | M-Score     | 32.80% | 26.11% | 25.38%* | 26.64%    | 40.16%    | 31.25               |

Python and C/C++ datasets. The performances of GPT-4 with  $P_c$  exhibit different changes across different datasets, with an improvement in the C/C++ dataset but a decrease in the Python dataset. However, all other LLMs achieved higher performance scores across both datasets.

**$P_{cid}$ :** Under  $P_{cid}$ , GPT-4, GPT-4 Turbo, Gemini Pro, Llama 2 7B and Llama 2 70B all achieved their best performance on both the Python and C/C++ datasets, while GPT-3.5 experienced a significant drop in scores. However, the impact of  $P_{cid}$  on the performance of DeepSeek-R1 was language-specific: while it led to a decline in C/C++, it enhanced performance in Python. It can be inferred that adding information related to CWE to the prompt generally enhances the capabilities of general-purpose LLMs in security code review. Notably, under  $P_c$ , the decrease in GPT-4's I-Score (Python: 4.76%  $\rightarrow$  3.24%, C/C++: 4.45%  $\rightarrow$  3.91%) and in M-Score (Python: 61.31%  $\rightarrow$  46.47%, C/C++: 55.47%  $\rightarrow$  44.53%) reflects that guiding LLMs to reference CWE in the prompt indeed enables GPT-4 to detect more security defects. Still, it does not guarantee the accuracy of the detection results. Under  $P_{cid}$ , providing a specific CWE list as a reference in the prompt leads to significant improvements across all metrics and datasets for GPT-4. Hence, incorporating specific CWE entries in the prompt is worthy of consideration. For DeepSeek-R1, we analyzed why the impact of  $P_{cid}$  on performance is programming language-specific. As mentioned in Section 2.2, Race Condition is the most prevalent security defect type in the Python dataset. The CWE list provided in  $P_{cid}$  includes CWE-435, which is highly relevant to Race Condition, thereby enhancing model performance. In contrast, the C/C++ dataset features a more balanced distribution of security defect types, such as Integer overflow, Resource Leak and Crash. We included solely high-level CWE entries in the CWE list and some of them, such as CWE-682 (Incorrect Calculation), do not exactly match certain security defect types like Integer Overflow. These CWE entries failed to provide sufficient guidance and even introduced interference. More fine-grained subtypes may provide better guidance for specific security defect types. Therefore, determining the optimal granularity of CWE as auxiliary information for different LLMs in security defect detection warrants further investigation in future work.

### 3.1.3. RQ1.3

Table 3 and Table 4 illustrate that  $P_{cot}$  significantly enhances the ability to detect security defects for Llama 2

7B and Llama 2 70B in both Python and C/C++ datasets. However, for Gemini Pro, GPT-4 Turbo and DeepSeek-R1, there is no improvement and even a detrimental effect to these LLMs. As for GPT-3.5 and GPT-4, they respectively exhibit improvement and decrease in their performances across different datasets. It can be seen that the impact of supplementing missing context by CoT prompting on the performance of LLMs is multifaceted and unstable. A possible explanation is that different LLMs vary in their ability to process and understand input. Moreover, we instructed the LLM to generate missing code context based on the corresponding commit message in  $P_{cot}$ . On the one hand, the generated context may contain the critical information needed to analyze the target security defect, which can help the LLM in security code review. On the other hand, the consistency between this generated context and the actual code context cannot be guaranteed. We observed that in some cases, the code context generated under Prompt  $P_{cot-1}$  was inconsistent with the actual code context, resulting in the original security defect no longer being identified as a defect within the generated context. Consequently, when Prompt  $P_{cot-2}$  was applied, the detection of security defects in the provided code was misled by the generated code context and yielded erroneous results.

To isolate the impact of LLM-generated code context on model performance, we designed  $P_{cot-guardrail}$  and conducted experiments under this prompt on the best-performing model, DeepSeek-R1.  $P_{cot-guardrail}$  retains CoT guidance and commit message but does not include the fabricated code context. The results are also presented in Table 3, Table 4 and Table 5. We observed that, on both the Python and C/C++ datasets,  $P_{cot-guardrail}$  consistently improved the performance of DeepSeek-R1 compared with  $P_b$ , whereas  $P_{cot}$  led to a performance decline. This suggests that for DeepSeek-R1, LLM-generated code context introduced interference for security code review. However, in the selected 57 instances, DeepSeek-R1 performed worse with  $P_{cot-guardrail}$  than with  $P_b$ . The 57 samples satisfy the token limits of all LLM-prompt combinations in our experiments, making them the samples with the fewest tokens in the dataset. Based on this, we hypothesize the following explanation: the commit message included in  $P_{cot-guardrail}$  helps the model understand code semantics and the CoT instruction drives the model to perform step-by-step reasoning, making this prompt more suitable for assisting the model in analyzing security defects in complex and long code. For

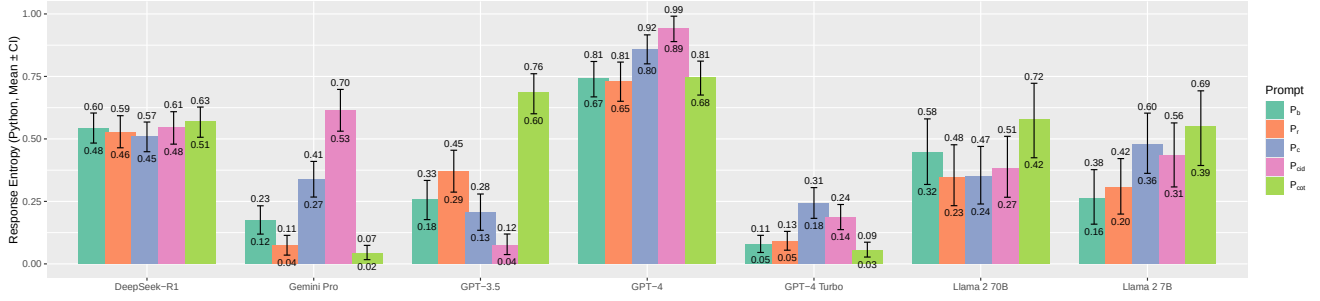


Figure 8: Response Entropy of each LLM-prompt combinations on the Python dataset

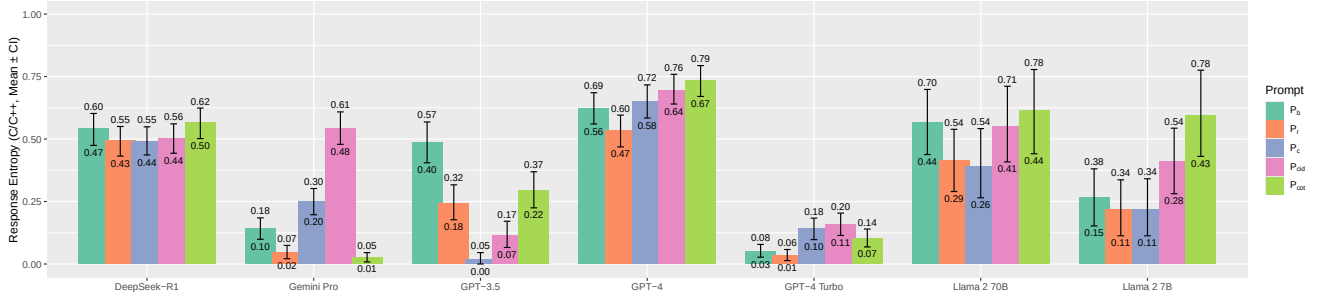


Figure 9: Response Entropy of each LLM-prompt combinations on the C/C++ dataset

code files with fewer tokens, these additional guidance could be unnecessary or even introduce noise to the LLM.

Missing code context can impact the reliability of model outcomes (Li et al., 2025), which remains a challenge when applying LLMs to real-world security code review. We attempted to generate code context using the LLM itself, but did not directly measure how often the LLM hallucinated irrelevant code and how such hallucinations affected model performance. This is because evaluating the consistency between LLM-generated code and the actual source code is challenging, as it requires a comprehensive understanding of the codebase and its historical commits. We plan to address this in future work. Some works have performed context augmentation by incorporating call graphs extracted through static analysis tools (Luo et al., 2024) or by utilizing caller-callee relationships within the code (Wen et al., 2024; Gao et al., 2023; Sun et al., 2024). Given this, we will also compare these approaches with the LLM-driven code context generation in assisting LLMs with security code reviews, and explore how to better leverage the capabilities of LLMs to obtain more effective and precise code context.

### 3.1.4. RQ1.4

According to the mean entropies and their 95% confidence intervals (CI) of various LLM-prompt combinations in Fig. 8 and Fig. 9, we found that GPT-3.5, GPT-4 Turbo, and Gemini Pro exhibit relatively higher consistency in their responses across three repetitive experiments, followed by Llama 2 7B, Llama 2 70B and DeepSeek-R1, with GPT-4 showing the least consistency.

Specifically, on the Python dataset, the highest consistency of responses was observed under  $P_{cor}$  with Gemini Pro, with a mean entropy of 0.0404 (95% CI: [0.02, 0.07]). On the C/C++ dataset, the combination of GPT-3.5 and  $P_c$  demonstrates the lowest mean entropy of 0.0195 (95% CI: [0.00, 0.05]). Given these two LLM-prompt combinations' poor security defect detection capabilities, their high consistency may be due to their tendency not to detect any security defects in the code. On the Python dataset, the highest average entropy of 0.9416 (95% CI: [0.89, 0.99]) was observed with the combination of GPT-4 and  $P_{cor}$ . On the C/C++ dataset, GPT-4 paired with  $P_{cid}$  exhibited the highest average entropy of 0.7330, with a 95% CI from 0.67 to 0.79. Compared with other LLMs excluding DeepSeek-R1, GPT-4 not only demonstrated significantly superior performance, but also exhibited the highest uncertainty. In comparison with GPT-4, DeepSeek-R1 showed improved performance in the security code review task but produced more stable outputs. However, the average entropy of DeepSeek-R1 remained relatively high among all models evaluated in our experiments. As shown in Table 1, we kept the decoding parameters at their default settings for all models. Except for DeepSeek-R1, the temperature and top\_p values of all LLMs fell within a similar range (0.9–1.0). Despite this, we observed substantial differences in response consistency across models. Furthermore, although DeepSeek-R1 was configured with a lower top\_p value (0.7), its response consistency was still relatively poor among all models. This observation suggests that decoding parameters alone may have a limited effect on regulating output consistency, and the observed

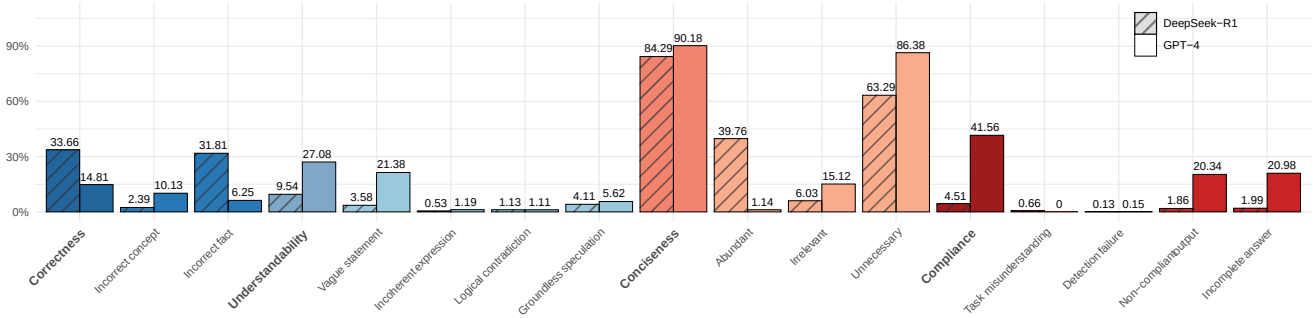


Figure 10: Average proportion of each problem type present in responses generated by GPT-4

differences are more likely attributable to model-intrinsic randomness.

### 3.2. Quality Problems in Responses (RQ2)

#### 3.2.1. RQ2.1

The average distribution of 13 problem types across four themes in the responses of *GPT-4+P<sub>cid</sub>* and *DeepSeek-R1+P<sub>cot-guardrail</sub>* to three repetitive experiments is illustrated in Fig. 10. The same color represents types within the same theme, with darker shades indicating the corresponding theme. We differentiate the two LLM+prompt combinations by whether the bars are filled with stripe patterns. For brevity, we will refer to the two combinations as GPT-4 and DeepSeek-R1 in the rest of this section. The four themes are **Correctness**, **Understandability**, **Conciseness** and **Compliance**. **Correctness** indicates problems where the response deviates from objective facts or common knowledge in the field of security. **Understandability** pertains to problems including inappropriate logic, unclear expressions, or incorrect attribution, which make the response difficult to comprehend. **Conciseness** refers to problems related to excessive verbosity or overly complex expressions. **Compliance** involves problems where the response fails to meet the requirements outlined in the task prompt.

For GPT-4, most responses contained problems related to **Conciseness**, accounting for 90.18%. Nearly half of the responses (41.56%) involved **Compliance**-related problems. Furthermore, 27.08% of the responses showed problems with **Understandability** and problems related to **Correctness** were the least frequent, occurring in only 14.08% of the responses. In the responses of DeepSeek-R1, **Conciseness** problems were also the most prevalent, accounting for 84.29%. However, the frequencies of problems related to **Compliance** and **Understandability** were significantly lower than those of GPT-4, at 4.51% and 9.54%, respectively. Moreover, DeepSeek-R1 was much more prone to **Correctness** problems than GPT-4, with a rate of 33.66%. The typical types of problems within each theme are described in detail below.

**Correctness:** The responses revealed two types of incorrectness: *Incorrect fact* (GPT-4: 6.25%, DeepSeek-R1: 31.81%) and *Incorrect concept* (GPT-4: 10.13%, DeepSeek-R1: 2.39%). The responses with *Incorrect fact* include:

incorrect line numbers of the code, function names not matching the source code provided, names not corresponding to the CWE-ID, and the described code content not matching the actual scenario. *Incorrect concept* indicates a misunderstanding of the concept of a certain CWE-ID or a specific security defect type. As shown in the example below (Example 1), the inaccurate comparison logic described in the response was mistakenly categorized as CWE-682, thus the response is considered to exhibit the *Incorrect concept* problem. Compared with GPT-4, DeepSeek-R1 exhibited a lower frequency of *Incorrect concept* problems, but its *Incorrect fact* rate was significantly higher. We observed that during security code reviews, GPT-4 tended to provide the range of code lines where defects were located, while DeepSeek-R1 often identified specific code lines and their corresponding code, making it more prone to errors in details. This may contribute to the higher *Incorrect fact* rate of DeepSeek-R1 compared to GPT-4. When applying LLMs to real-world security code reviews, we expect models to provide both specific and accurate factual information. Therefore, how to enhance the capability of LLMs to retain code details with precision requires further exploration.

#### Example 1 - Incorrect concept

```
GPT-4: ...**CWE-682 (Incorrect Calculation):**
**Issue:** The method `_inventory_has_changed` uses a comparison
logic that might not be entirely accurate in all scenarios...
```

**Understandability:** Problems that reduce understandability of responses include *Vague statement* (GPT-4: 21.38%, DeepSeek-R1: 3.58%), *Incoherent expression* (GPT-4: 1.19%, DeepSeek-R1: 0.53%), *Logical contradiction* (GPT-4: 1.11%, DeepSeek-R1: 1.13%), and *Groundless speculation* (GPT-4: 5.62%, DeepSeek-R1: 4.11%). For GPT-4, *Vague statement* is the most prevalent one. It refers to a situation where the description of the detected security defect is not specific enough, failing to pinpoint the defect to a specific location or providing an overly general fix suggestion. An example (Example 2) of *Vague statement* is shown below, in which GPT-4 did not provide a concrete location or line number for the identified security defect in the response. While for DeepSeek-R1, the frequency of *Vague statement* was considerably lower than that of GPT-4. We speculated that its reasoning procedure under the



‘think’ mode somewhat contributed to generating specific and detailed responses.

**Example 2 - Vague statement**

```
GPT-4: ...
**CWE-703(Improper Check or Handling of Exceptional Conditions)**
**General Concern**: Throughout the code, there are instances where
error conditions might not be handled comprehensively...
```

**Conciseness:** In all responses, some of them contain *Redundant* content (GPT-4: 1.14%, DeepSeek-R1: 39.76%), some include information *Irrelevant* to the task of security defect detection (GPT-4: 15.12%, DeepSeek-R1: 6.03%), and some contain *Unnecessary* elements (GPT-4: 86.38%, DeepSeek-R1: 63.29%), all of which are problems related to the conciseness of the response. We found that DeepSeek-R1 was more likely than GPT-4 to repeatedly mention the same information in its output, whereas GPT-4 produced content that is unrelated to the target task more frequently. Including *Unnecessary* content, which refers to information that is somewhat related to security code review but does not contribute to detecting security defects, is the most prevalent problem for both GPT-4 and DeepSeek-R1. Such information includes the reasons for the absence of security defects in the current code and general suggestions on security measures and review processes. As illustrated in the example below (Example 3), the response indicates that no defect related to CWE-284 exists in the code and further elaborates on the reason. However, this is not the content we required GPT-4 to generate in the prompt, hence it is deemed to be *Unnecessary* information.

**Example 3 - Unnecessary**

```
GPT-4: ...**CWE-284 (Improper Access Control)**:
- There doesn't seem to be any direct issue related to improper
access control in the given code...
```

**Compliance:** Four types of non-compliance were identified regarding whether the responses satisfied the requirements in the prompts. Among them, *Detection failure* was observed in very few responses (GPT-4: 0.15%, DeepSeek-R1: 0.13%), where LLM explicitly claimed that it could not perform a security check in its response or was stuck in an infinite output loop and failed to complete the security defect detection task. *Task misunderstanding*, which is similarly rare (GPT-4: 0.00%, DeepSeek-R1: 0.66%), indicates that LLM misinterprets the task details in the prompt. For instance, when using DeepSeek-R1 with  $P_{cot-guardrail}$ , if the commit message mentioned security defects addressed by the current commit, LLM may mistakenly interpret the task of security code review as explaining the security defects mentioned in the commit message. *Non-compliant output* was present in 20.43% of GPT-4 responses, in which GPT-4 fails to include the fixed phrase ‘No security defects are detected in the code’, when no defects are found. *Incomplete answer* is the most common problem (20.98%) under this theme for GPT-4, referring to cases in which the responses lack the line numbers or fix suggestions of detected security defects requested in the prompt. Although GPT-4 showed relatively high frequencies for these two problems, DeepSeek-R1 exhibited much lower rates for them, at 1.86%

and 1.99%, respectively. Given this, we consider DeepSeek-R1 to exhibit stronger instruction-following capabilities than GPT-4 in security code review. The example below (Example 4) shows that while the potential memory management issues caused by temporary files and directories are described and a fix suggestion is provided, no specific line numbers are given. Hence, it is categorized as an *Incomplete answer*.

**Example 4 - Incomplete answer**

```
GPT-4: ### 3. CWE-664
**Potential Issue**: The creation of temporary files and
directories (e.g., in function `createQmlrcFile`) ... can
potentially lead to resource management issues.
**Solution**: Implement thorough checks and error handling...
```

While Kabir et al. (2024) also evaluated the quality problems in LLM-generated responses, the application domain of LLMs and the distribution of identified problems in their work differ from ours. Specifically, Kabir et al. (2024) requested ChatGPT to answer programming questions on Stack Overflow and found that ChatGPT makes fewer factual errors compared to conceptual errors. This aligns with our findings for GPT-4. However, unlike their study, which identified correctness problems in over half (52%) of the responses, our study applied GPT-4 to security code review, revealing a much lower incidence of correctness issues at 14.81%. When applying DeepSeek-R1, the frequency of correctness problems increased to 33.66%. This suggests that the distribution of quality problems in LLM responses may vary significantly across different application domains and model architectures, necessitating distinct optimization directions and strategies in practical application.

### 3.2.2. RQ2.2

We selected all items related to hallucination from the quality problem types in RQ1.1 and mapped them to the predefined set of hallucination subtypes. The details of mapping, corresponding explanations, and proportion results are shown in Table 7. Since a single response may exhibit multiple types of hallucination simultaneously, the sum of the proportions for each subtype exceeds the proportion of responses containing at least one hallucination. Overall, 20.19% of GPT-4 responses contained hallucinations, whereas DeepSeek-R1 exhibited a higher rate of 36.45%. The former encountered more *Factuality Hallucination*, while the latter was predominantly affected by *Faithfulness Hallucination*. Specifically, for GPT-4, *Factual Contradiction* was the most frequent subtype, accounting for 10.13%, followed by *Context Inconsistency* (6.25%) and *Factual Fabrication* (5.62%). In contrast, for DeepSeek-R1, *Context Inconsistency* was the most prevalent subtype (31.81%), with *Factual Fabrication* and *Factual Contradiction* following at 4.11% and 2.39%, respectively. To alleviate these hallucinations, Retrieval-Augmented Generation (RAG) can be employed to incorporate external factual information (Tonmoy et al., 2024; Lewis et al., 2020), and post-training can also be applied to enhance the model’s capability to capture and retain contextual knowledge (Kumar et al., 2025).

**Table 7**

Mapping of hallucination and quality problem types with corresponding proportions.

| Halluc. Type*              | Subtype                   | QP Type*                                 | Explanation                                                                                                                                                                                                                             | Prop.*        |               |
|----------------------------|---------------------------|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|---------------|
|                            |                           |                                          |                                                                                                                                                                                                                                         | GPT-4         | DS-R1         |
| Factuality Hallucination   | Factual Contradiction     | Incorrect Concept                        | In <i>Incorrect Concept</i> cases, the model's output contradicts the authoritative definition of the corresponding CWE, thus categorized as <i>Factual Contradiction</i> .                                                             | <b>10.13%</b> | 2.39%         |
|                            | Factual Fabrication       | Groundless Speculation                   | <i>Groundless speculation</i> refers to subjective assumptions made without contextual evidence or knowledge support. As it involves fabricated factual content, it is categorized as <i>Factual Fabrication</i> .                      | <b>5.62%</b>  | 4.11%         |
| Faithfulness Hallucination | Instruction Inconsistency | Detection Failure, Task Misunderstanding | <i>Detection Failure</i> refers to cases where the model fails to perform the security checks or misinterprets the task, leading to deviations from the instruction. Therefore, it is categorized as <i>Instruction Inconsistency</i> . | 0.15%         | <b>0.80%</b>  |
|                            | Context Inconsistency     | Incorrect Fact                           | <i>Incorrect Fact</i> denotes cases where the line numbers, identifiers, or code content generated by the model do not align with the provided code context, thus categorized as <i>Context Inconsistency</i> .                         | 6.25%         | <b>31.81%</b> |
|                            | Logical Inconsistency     | Logical Contradiction                    | <i>Logical Contradiction</i> refers to cases where the model's reasoning about a security defect is internally contradictory, thus classified as <i>Logical Inconsistency</i> .                                                         | 1.11%         | 1.13%         |
| <b>Any Hallucination</b>   |                           |                                          |                                                                                                                                                                                                                                         | <b>20.19%</b> | <b>36.45%</b> |

\* Abbreviations: Halluc. = Hallucination, QP = Quality Problem, Prop. = Proportion.

### 3.3. Factors Influencing LLMs (RQ3)

#### 3.3.1. Model Stability

To assess the adequacy of the fit of regression models for  $GPT-4+P_{cid}$  and  $DeepSeek-R1+P_{cot-guardrail}$ , we utilized Nagelkerke's Pseudo  $R^2$  (Nagelkerke et al., 1991). This yielded values of 0.097 for GPT-4 and 0.090 for DeepSeek-R1, which are relatively lower than the value of regression analysis in other fields reported in e.g., (Paul et al., 2021; Turzo, 2022). A possible explanation is that although we have considered the non-determinism of LLM responses during model fitting, the random effects incorporated into our models may not be sufficient to capture all the random variation in the datasets. Nonetheless, through a log-likelihood ratio test using the *anova* function of the *ordinal* R package (Christensen and Christensen, 2015), we found that our regression models exhibit significant explanatory power over a null model: for GPT-4,  $LR\chi^2 = 112.73$ ,  $P_r(>\chi^2) < 0.0001$ ; for DeepSeek-R1:  $LR\chi^2 = 122.02$ ,  $P_r(>\chi^2) < 0.0001$ . Given that Our goal is to construct an inferential regression model rather than a predictive one, these two regression models with relatively lower  $R^2$  can still provide valid insights into the relationship between explanatory variables and response variables (Allison, 2014).

#### 3.3.2. Explanatory Power of Each Factor

The Wald statistic is employed to evaluate the explanatory power exerted by each factor on the response variable. A larger Wald  $\chi^2$  with a smaller *p-value* indicates that the variable has more significant predictive power for the regression model. We calculated the  $\chi^2$  and *p-value* of each factor and adopted the commonly used significance level of 0.05 to evaluate their impact.

As shown in Table 8, for GPT-4, 'Token' wielded the highest predictive power on the fitted model, with the highest  $\chi^2$  (54.20) and the lowest *p-value* ( $<0.0001$ ). Trailing closely behind were 'FileType' and 'AnnotationIsSecurityRelated' factors, with correspondingly significant contributions ( $\chi^2=19.04$ ,  $p<0.0001$ ) and ( $\chi^2=15.46$ ,  $p=0.0004$ ).

Adding to this, 'Community' and 'Commit' displayed less influence but remained noteworthy, with  $\chi^2$  values of 8.14 and 4.82, respectively. For DeepSeek-R1, 'Complexity' and 'AnnotationIsSecurityRelated' demonstrated the strongest explanatory power over the response variable, with  $\chi^2$  of 15.51 and 14.02, and *p-values* both less than 0.001. Following closely were 'SecurityDefectType' and 'Token', with *p-values* of 0.0017 (less than 0.01), indicating that they also have a statistically significant impact on the model's performance in security code review. Although the  $\chi^2$  for 'Community' (6.03), 'FileType' (5.57) and 'AnnotationHasCode' (4.37) were relatively smaller, they still contributed predictive value in the fitted model. Factors not analyzed here were deemed not to largely influence the performance of GPT-4 and DeepSeek-R1 in detecting security defects in code reviews, as their *p-values* exceeding the 0.05 threshold and  $\chi^2$  values were much lower than those discussed factors. Notably, 'SecurityDefectType' had a relatively high  $\chi^2$  value (11.29 for GPT-4 and 28.12 for DeepSeek-R1), which could be attributed to the fact that this factor is a nominal variable with multiple categories of security defects, thus automatically allocated a high number of degrees of freedom. As a result, even if this factor is not significant, its relative contribution ( $\chi^2$ ) remains elevated.

#### 3.3.3. Relationships between Factors and Responses

The odds ratio (OR) is commonly used to measure the relationships between explanatory and response variables (Paul et al., 2021; Thongtanunam et al., 2017; Setia, 2016). In this study, the OR represents the odds of LLM generating a better response in security code review versus not generating a better response. For categorical explanatory variables, the OR compares each category to a reference category. For interval variables, the OR reflects the effect of a one-unit increase in the explanatory variable. We utilized the *summary* function of the *rms* package (Harrell Jr et al., 2017) to calculate the OR for each factor (see Table 8).

**Table 8**Explanatory powers of factors to the performance of GPT-4 under  $P_{cid}$  in security code review.

| Factor (:Reference)         |                                 | GPT-4 |      |          |            | DeepSeek-R1 |      |          |            |
|-----------------------------|---------------------------------|-------|------|----------|------------|-------------|------|----------|------------|
|                             |                                 | OR    | D.F. | $\chi^2$ | Pr(>Chi)   | OR          | D.F. | $\chi^2$ | Pr(>Chi)   |
| Token                       |                                 | 0.63  | 1    | 54.20    | < .0001*** | 0.44        | 3    | 9.81     | 0.0017**   |
| Position                    |                                 | 0.89  | 1    | 0.2685   | 0.6042     | 1.15        | 1    | 0.47     | 0.4909     |
| Community                   | Qt:Openstack                    | 1.54  | 1    | 8.14     | 0.0043**   | 1.41        | 1    | 6.03     | 0.0141*    |
| FileType                    | Source:Auxiliary                | 2.81  | 1    | 19.04    | < .0001*** | 0.57        | 1    | 5.57     | 0.0183*    |
| AnnotationisSecurityRelated | -1:0                            | 1.04  | 2    | 15.46    | 0.0004***  | 1.28        | 2    | 14.02    | 0.0009***  |
|                             | 1:0                             | 2.91  |      |          |            | 2.57        |      |          |            |
| AuthorExperience            |                                 | 0.93  | 1    | 1.29     | 0.2569     | 0.96        | 1    | 0.65     | 0.4203     |
| Commit                      |                                 | 1.01  | 1    | 4.82     | 0.0281*    | 1.00        | 1    | 0.01     | 0.7379     |
| SecurityDefectType          | Buffer Overflow:Race Condition  | 0.84  | 10   | 11.29    | 0.3353     | 1.25        | 10   | 28.12    | 0.0017**   |
|                             | Crash:Race Condition            | 0.94  |      |          |            | 1.01        |      |          |            |
|                             | Deadlock:Race Condition         | 0.83  |      |          |            | 0.93        |      |          |            |
|                             | DoS:Race Condition              | 0.98  |      |          |            | 1.99        |      |          |            |
|                             | Encryption:Race Condition       | 0.83  |      |          |            | 4.43        |      |          |            |
|                             | Improper Access:Race Condition  | 0.80  |      |          |            | 2.16        |      |          |            |
|                             | Integer Overflow:Race Condition | 0.85  |      |          |            | 1.16        |      |          |            |
|                             | Resource Leak:Race Condition    | 1.49  |      |          |            | 1.14        |      |          |            |
|                             | Use After Free:Race Condition   | 0.41  |      |          |            | 0.84        |      |          |            |
|                             | Extra:Race Condition            | 0.74  |      |          |            | 1.99        |      |          |            |
| Complexity                  |                                 | 1.03  | 1    | 2.60     | 0.1071     | 1.08        | 1    | 15.51    | < .0001*** |
| AnnotationRatio             |                                 | 0.60  | 1    | 1.30     | 0.2538     | 1.16        | 1    | 0.11     | 0.7379     |
| AnnotationHasCode           |                                 | 0.83  | 1    | 1.03     | 0.3094     | 1.46        | 1    | 4.37     | 0.0364*    |

Statistical significance of explanatory power according to Wald  $\chi^2$  test:\* $p < 0.05$ ; \*\* $p < 0.01$ ; \*\*\* $p < 0.001$ 

As presented in Table 8, for both DeepSeek-R1 and GPT-4, the OR for the ‘token’ factor was less than 1, indicating that the models are more likely to detect security defects in code files with fewer tokens. The OR values for ‘AnnotationisSecurityRelated’ and ‘community’ were greater than 1, suggesting that the two models are more likely to detect security defects in code files that include security-related annotations and originate from the Qt community, rather than from OpenStack. However, regarding ‘FileType’, GPT-4 and DeepSeek-R1 showed opposing results. GPT-4 had an OR of 2.81 ( $> 1$ ), indicating a higher likelihood of detecting security defects in source code with functional logic, while DeepSeek-R1 had an OR of 0.57 ( $< 1$ ), suggesting better performance on header files utilized for declaration. Furthermore, DeepSeek-R1 exhibited varying detection capabilities for different types of security defects. According to the OR values of ‘SecurityDefectType’, DeepSeek-R1 demonstrated a greater tendency to detect various other security defect types compared to Race Condition, including but not limited to Encryption, Buffer overflow, Integer Overflow, and Resource leak. In addition, DeepSeek-R1 displayed stronger capabilities in security defect detection for files with more code complexity, as evidenced by its OR for ‘complexity’ being greater than 1 (1.08). This contrasts with the consensus in previous works that as complexity of software grows, security defects are becoming more challenging to detect Sheng et al. (2024). A possible explanation is that we utilized McCabe’s Cyclomatic Complexity McCabe (1976) to measure this factor, which is not always positively correlated with the actual difficulty of detection. Code with higher cyclomatic complexity may have a clearer code structure and retain more contextual information within the single code file, which could better support DeepSeek-R1’s reasoning procedure during its think mode. On the other hand, the analysis of security defects in code with lower cyclomatic complexity may require more cross-file code context and

project-specific knowledge, leading to DeepSeek-R1 struggles to determine whether security defects exist.

It is also worth noting that while previous studies have explored the relationship between the position of security defects and the performance of LLMs, our findings differ. According to the study by Sovrano et al. (2025), the ‘position’ of security defect was determined by counting the characters preceding the security defect and they concluded that security defects located at the end of the code file are often harder to detect. However, when the file itself contains a large number of characters, even if the defect is located in the relatively middle or beginning part of the file, its ‘position’ can still be quite high. Therefore, the logistic regression analysis in Sovrano et al. (2025) was to some extent confounded by the effect of character count (or token count). Our study, by measuring ‘position’ as the ratio of tokens preceding the security defect relative to the total token count, reduced the correlation between ‘Position’ and ‘Token’. It can be seen from Table 8 that in both of the two fitted models, the p-values of ‘Position’ were far greater than 0.05, indicating that the position of security defect has no significant effect on the performance of either GPT-4 or DeepSeek-R1. While the OR of ‘Position’ (0.89) in GPT-4 was less than 1, consistent with Sovrano et al. (2025), DeepSeek-R1 showed an OR of 1.15, which is greater than 1. Therefore, the impact of the position of security defect in code files on the detection performance of latest reasoning models warrants further analysis and validation.

#### 4. Discussion

*A multi-layered review strategy is suggested to apply LLMs to security code review.* As the results of RQ1 indicate, the existing general-purpose LLMs still fall significantly short of reaching the effectiveness of manual security code review. However, LLMs can serve as auxiliary tools to assist reviewers. We recommend a multi-layered review

strategy to fully leverage the capability of LLMs. The findings of RQ3 suggest that LLMs are more adept at identifying security defects in code file with fewer tokens and higher cyclomatic complexity. Utilizing these two factors, a lightweight model can be trained to classify the code file to be reviewed into the low-difficulty or high-difficulty groups. Firstly, LLMs are utilized to conduct an initial automatic review of these files. Then, for low-difficulty code, reviewers quickly confirm the security defects identified by LLMs. Code in which LLMs did not detect any security defects would then be resampled and rechecked to confirm its security. For high-difficulty code, reviewers utilized the detection results of LLMs as a reference, combined with their own domain knowledge, to perform a more thorough and in-depth analysis of the submitted code. This approach aims to improve the efficiency of security code review while minimizing the risk of missing security defects. Additionally, reviewers should provide feedback on each of the detection results generated by LLMs, which can then be used to train both the difficulty classification model and LLMs for security code review.

**When using a CWE list as auxiliary information for LLM in security code review, the granularity of CWE entries is crucial.** Our findings indicate that incorporating a CWE list into prompts significantly improves the performance of various LLMs in security defect detection, which aligns with the results of Steenhoek et al. (2024a). However, in real-world security reviews, although with experience and domain knowledge, the reviewers lack prior knowledge of all potential types of security defects that may be present in the code. It should also be noted that an overly exhaustive scope can diminish the accuracy of LLM responses. In Bakhshandeh et al. (2023), providing a list of all 75 CWEs in their prompts decreased the accuracy of security defect detection and location by the LLMs. This drop in accuracy may be attributed to the overly lengthy and detailed list of CWEs provided, which interferes with the LLM's capability to focus effectively on the target defect, yielding adverse effects. Therefore, constructing a concise yet comprehensive CWE list is necessary. In our experiments, due to the limited context length of the used LLMs, inputting the entire codebase during prompt design was not feasible. The lack of code context made it difficult for the LLM to fully understand the dependencies and interaction logic between files, which in turn affected its performance in identifying security defects, such as *Race Condition* and *Insecure Library Version*. We tested various approaches, including one-shot and few-shot prompting strategies, as well as providing the complete patchset within the prompt. These strategies required splitting the code into sections for input, which we found significantly degraded the performance of LLMs compared to the basic prompt  $P_b$ . In order to provide as much effective information as possible within the limited context window, we designed prompts that combined multiple elements, including project metadata, CWEs, code diffs, and the commit messages. We also standardized the output format to help the model better understand the task and

introduced CoT reasoning to guide the model in inferring missing context. Ultimately, we identified and selected four prompts that outperformed others, which, together with the basic prompt, were selected as templates for our formal experiments. The results in RQ1.3 demonstrate that for GPT-4, including a CWE list in the prompt significantly enhances LLM performance, while for DeepSeek-R1, the impact of the provided CWE list on model performance depends on the specific programming language. We therefore emphasize the need to explore CWE entries of different granularities for various types of security defects to determine the optimal CWE list. As the context window of LLMs continues to expand and prompt engineering techniques evolve, we also plan to explore additional strategies in the future, such as incorporating RAG for external information, employing automated prompt optimization to dynamically adjust prompts, and leveraging the agent architecture to dynamically invoke contextual information during reasoning, thereby further improving the capability of LLMs in security defect detection.

**With the development of LLMs, while expanding its context window, it is also necessary to ensure that LLMs can accurately capture details from long inputs.** The emergence of LLMs that support large amounts of tokens has alleviated the challenge of inputting code context information in applying LLMs to code-related tasks. However, as evidenced by the results of RQ3, when dealing with code that contains more tokens, it is more difficult for LLMs to identify target security defects. This is because many security defects are introduced by small code snippets, and longer inputs may distract LLMs from overlooking certain details, thereby failing to detect security defects introduced by small code snippets. Additionally, according to RQ1, for general-purpose LLMs, despite GPT-4 Turbo having a context of 128K tokens, its performance in detecting security defects is noticeably inferior to that of smaller-context LLMs like GPT-4, GPT-3.5, and *Llama 2*. While for the reasoning-optimized LLM, although DeepSeek-R1 also has a 128k context window and is the best-performing model in this study, its rate of *Incorrect fact* reaches as high as 31.81%. Specifically, DeepSeek-R1 often presented problems with mismatched code line numbers and code snippets in its responses, which significantly undermines the understandability of its analysis. Therefore, while expanding the LLMs' context window, it is also necessary to guarantee the model's precise memory of detailed information such as key code segments, to enhance the accuracy of security defect detection and the clarity of defect descriptions.

**A key challenge in applying LLMs to security code review is ensuring comprehensive detection of security defects while maintaining consistent results.** The results from RQ1.4 indicate that the two LLMs (DeepSeek-R1 and GPT-4) with stronger capabilities to detect security defects tend to exhibit poorer consistency in their responses. This may be because LLMs with better performance are more capable of reasoning from multiple perspectives. The inherent randomness of LLM leads to variations in reasoning paths, resulting in inconsistent outcomes. In comparison,



the thought of less capable models is relatively shallow, and their strong consistency in responses may stem from failing to deeply analyze the code. The security code review task requires models to explore as many reasoning paths as possible in order to maximize the recall of security defects, making the inconsistency of responses inevitable. In real-world application of LLMs for security code review, both the accuracy and stability of detection results are crucial. However, current studies related to LLMs in vulnerability detection have largely overlooked the importance of the stability of results. Therefore, for researchers, exploring approaches to improve the detection sensitivity while maintaining result stability, such as through more precise contextual information or voting mechanisms, is a valuable direction for future improvement.

**Reasoning models exhibit limited sensitivity to logic-related security defects during security code review** The results from RQ3 show that DeepSeek-R1 underperformed in detecting race conditions compared to most other security defect types. Previous studies have also demonstrated that the detection accuracy of LLMs suffers from an imbalance across different security defect types, with race conditions being relatively underexplored Sheng et al. (2025). Given that Race Condition is a high-frequency type of security defect in Python projects (accounting for 65.1% on the Python dataset in this study, see fig. 3), it is crucial to guide LLMs to pay more attention to logic-related security defects. Based on the results of RQ1,  $\mathbf{P}_{cid}$  and  $\mathbf{P}_{cot-guardrail}$  enhanced DeepSeek-R1's capability of detecting security defect detection. To separately analyze their effect on race conditions, we further calculated the IH-Scores of DeepSeek-R1 on code files with race conditions from the complete dataset (Python and C/C++) under  $\mathbf{P}_b$ ,  $\mathbf{P}_{cid}$ , and  $\mathbf{P}_{cot-guardrail}$ , which were 5.09%, 7.56%, and 6.02%, respectively. This suggests two potentially effective approaches to improve the sensitivity of LLMs on logical-related security defects: first, explicitly guiding the model to concentrate on the corresponding areas through CWE entries; and second, leveraging the commit message to assist LLMs in better understanding code functionality and logic implementation.

## 5. Threats to Validity

**Internal Validity** refers to whether an observed association between two variables can be attributed to a causal link between them. One of the internal validity threats could be **data leakage**. The data used in our study was obtained from two large-scale open-source projects, which may overlap with the data used for training LLMs, a common problem with LLM-based studies. Since the training data cutoff dates for the models used (GPT-3.5 and GPT-4) are not disclosed and the dataset we used (Yu et al., 2023) predates the release of some of the LLMs we selected, we cannot avoid the overlap between the dataset we used and the training data of LLMs by filtering the data for a specific period of time. Moreover, according to Cao et al.

(2024), contaminated data does not always affect the results, and the model sometimes even performs better after the model's cutoff date. Another threat is **the design of prompts**. We design our prompt according to best practices to evoke the best model performance. We selected words that are as unbiased, non-suggestive, and unambiguous as possible. We iteratively revised the prompts to avoid individual words from impacting the responses of LLMs during our preliminary exploration. In addition, we only included code from the single vulnerable file rather than the whole patchset in the prompt, which may affect the performance of LLMs due to **the lack of contextual information**. To explore approaches for context augmentation, we designed a prompt  $\mathbf{P}_{cot}$ , in which LLMs are instructed to reason step-by-step—generating code context according to the commit message before detecting security defects. Since multiple factors in  $\mathbf{P}_{cot}$  could influence model performance, we also designed  $\mathbf{P}_{cot-guardrail}$  as a control prompt that includes only the commit message and CoT instruction, in order to isolate the effect of the fabricated code context.

**External Validity** concerns whether a causal link generalizes across contexts. In this study, the experiments were conducted on 7 LLMs based on 4 open-source projects across programming languages including Python and C/C++. We acknowledge that the dataset we utilized may not fully represent industrial projects across various programming languages, and the performance of the selected LLMs may not represent the capabilities of all existing LLMs. We implemented the following strategies to ensure the generalizability of the experimental results. For **model diversity**, our experiments incorporated both open-source and proprietary LLMs of varying parameter scales to encompass a diverse range of popular general-purpose and reasoning-optimized LLMs. For **dataset construction**, we collected code review data from real-world open-source projects in the OpenStack and Qt communities. These projects differ in architectures, programming languages, and community structures, providing a comprehensive and valuable dataset for empirical analysis.

**Construct Validity** assesses whether a specific set of metrics corresponds to what they are intended to measure. To measure the performance of LLMs, we classified the natural language responses of LLMs into four predefined categories, with human reviews of security defects in code as the ground truth. There is a potential **natural language understanding bias** which affects classification accuracy. To reduce the bias, we established granular definitions for each category in three dimensions: defect type, location, and description, supplemented by examples for each category to ensure that the metrics are accurate, appropriate, and consistent throughout the evaluation process. In addition, the data labeling in RQ1 and the analysis of quality problems in RQ2 were all carried out manually. In order to further reduce the impact of **subjective judgments**, we employed open coding and constant comparison (Glaser, 1965). In the data labeling employed for RQ1, the first and third authors conducted a pilot data labeling and completed all

the labeling work after reaching a consensus on the criteria through discussion. In the data analysis of RQ2, the first and seventh authors, conducted two rounds of pilot data analysis to determine the definition of each quality problem and achieved a high level of consistency in the results. All discrepancies in the manual work of our study were reviewed and resolved through negotiation and discussion among at least three authors, thus ensuring the reliability of the findings.

**Conclusion Validity** refers to whether the conclusions drawn about relationships in the data are statistically sound and reasonable. Due to the **non-determinism of LLMs**, the same input may yield different outputs across different runs. Therefore, a single round of experiments is insufficient to accurately reflect the performance of LLMs. To enhance the reliability and representativeness of our evaluation, we repeated the RQ1 experiment three times. For RQ2, we calculated the average frequency of each problem across these three experiments. For RQ3, we combined the responses from the three experiments to fit the model. We also assessed their non-determinism as part of the overall performance. Specifically, in RQ1.4, we calculated the consistency of LLMs' responses across three runs to compare the non-determinism of different LLMs under different prompts.

## 6. Related Work

### 6.1. Security Defect Detection in Code Review

Several studies have analyzed security defect detection during code reviews. Paul et al. (2021) built a dataset from the Chromium OS project, consisting of 516 code reviews that successfully identified security defects and 374 code reviews that missed security defects. The study analyzed 18 code review attributes, including review duration, reviewer experience, and author experience, to explore factors influencing the identification of security defects. It was found that the duration of code reviews and the frequency of peer reviews positively affected the detection of security defects, while the number of directories under review and the number of prior commits had a negative impact. Alfadel et al. (2023) examined pull requests (PR) from 10 popular JavaScript GitHub projects within the npm ecosystem, then analyzed the frequency, categories, and handling of security defects identified during code reviews. Their work indicated that only a small fraction of PRs raise security problems, and most of the identified security problems were resolved during the code review.

### 6.2. Code Characteristics of Security Defects

Security defects mainly stem from improper system design or low-quality code, caused by a lack of security expertise or violations of secure coding practices during implementation. Many studies have focused on analyzing code for vulnerabilities and security defects in hopes of helping developers understand how security problems originate in a system, so that defects are detected early.

Alves et al. (2016) constructed a security defect dataset based on five widely used projects and 27 software metrics,

such as lines of code, cyclomatic complexity and knots in the control flow graph, among others. This study demonstrated that most of these metrics are effective in distinguishing vulnerable from non-vulnerable code, thereby providing valuable support for security practitioners. Meneely et al. (2013) conducted quantitative and qualitative analyses on 124 Vulnerability-Contributing Commits (VCC) in the Apache HTTP Server to identify characteristics of code changes with security defects. The findings suggest that longer lines of code and less experienced committers are more likely to introduce security defects. Bosu et al. (2014) identified 413 VCCs from code reviews in 10 open-source projects and reported consistent observations with Meneely et al. (2013) that longer lines of code and less experienced committers are more likely to introduce security defects. Additionally, they indicated that modified code files are more likely to contain security defects than new files.

### 6.3. Automated Tools of Security Defect Detection

Various tools have been developed to automatically detect security defects. Since our study focuses on using LLMs to assist reviewers in identifying security defects during code review, we limit our coverage to studies related to security defect detection, excluding those studies on security defect remediation or program repair.

Charoenwet et al. (2024) conducted an empirical study on the application of static application security testing tools (SASTs) in security code review and found that a single SAST tool could produce warnings for 52% of VCCs. By combining several tools, warnings could be produced for 78% of the VCCs. However, at least 76% of these warnings are irrelevant to the vulnerability in VCCs, highlighting the challenges that SAST tools face in providing detailed information about the vulnerability during security code review. Inspired by this work, **our work** investigated the application of LLMs in security code review, aiming to overcome the limitations of SAST tools to some extent.

Several studies have explored the performance of LLMs in detecting security defects. The majority of these studies conducted a coarse-grained assessment of LLMs in binary classification tasks that determine whether the code contains any security defects without specifying the corresponding defect type. Zhou et al. (2024) utilized CWE, project information, and a few-shot learning approach to design prompts and evaluated the capability of two popular LLMs, GPT-3.5 and GPT-4, in binary judgment under various prompts. They found that GPT-3.5 achieved competitive performance with the prior state-of-the-art detection approaches, while GPT-4 consistently outperformed the state-of-the-art. Purba et al. (2023) compared the performance of LLMs with popular static analysis tools in binary detection. Their work demonstrates that although LLMs achieved a good recall rate, their false positive rate was significantly higher than that of static analysis tools. Jensen et al. (2024) evaluated the performance of three proprietary OpenAI LLMs and four small-scale models with fewer than 13B parameters to identify vulnerabilities in the SecurityEval dataset (Siddiq and

Santos, 2022). They adopted zero-shot and CoT prompting and found that the best-performing model - GPT-4 - achieved an accuracy of 95.6% in distinguishing between vulnerable and patched versions of code. Similarly, Steenhoek et al. (2024b) assessed the capabilities of 14 LLMs on a real-world and function-level vulnerability dataset, SVEN, across seven different prompt strategies. They explored various approaches, including prompt optimization, scaling model size, increasing pre-training data, fine-tuning, and incorporating domain knowledge into prompts, yet none led to significant improvements in the performance of models in the binary vulnerability detection task. Unlike previous studies, **our work** provides a more fine-grained evaluation of the capability of LLMs in security code reviews by including additional insights such as defect localization, description, and suggestions for defect remediation.

Previous studies also investigated whether LLMs could provide more information in security defect detection. Bakhshandeh et al. (2023) provided LLMs with a list of CWEs and the inspection results of static analysis tools on the prompts, requesting the LLMs to generate specific CWE names along with the corresponding code line numbers. Their study shows that LLMs effectively reduce false positives of static tools and demonstrate competitive or even superior performance in defect localization compared to these tools. Yin et al. (2024) evaluated the performance of LLMs across multiple tasks in security analysis, including defect detection, localization, and description, and found that the existing state-of-the-art approaches, such as LineVul (Fu and Tantithamthavorn, 2022) and SVuID (Ni et al., 2023), generally outperformed LLMs. Specifically, LLMs exhibited limited overall accuracy and varied performance across different CWE types in defect localization and description tasks. Khare et al. (2025) comprehensively evaluated 16 pre-trained LLMs for detecting security defects on a function-level vulnerability dataset of 5,000 samples. Their study systematically compared model performance across three distinct prompting strategies and found that involving step-by-step analysis significantly improved LLM performance. This work also performed comparison of LLMs against leading static analysis tools and deep learning-based approaches, finding that LLMs reported higher detection accuracies than them. These studies have all been limited to quantitatively evaluating LLM performance. In comparison, **our work** performed an in-depth analysis of the quality problems in LLM-generated responses and factors affecting LLM performance to understand the potential and challenges LLMs face in security code review.

Fine-tuning has also been employed to improve the capability of LLMs in security defect detection. Mechri et al. (2025) fine-tuned CodeQwen1.5-7B on a large Python dataset comprising both real-world code and synthetic code generated by LLMs, in order to guide the model to capture and classify security defects in code accurately. The model ultimately achieved high accuracy, with F1 scores ranging from 84% to 99%. Although fine-tuning can effectively improve the accuracy of model, fine-tuned LLMs often

exhibit poor generalization. In practical application, adjustments to the model parameters and subsequent retraining are usually required. Consequently, some studies have shifted their focus toward approaches that avoid altering the core model, such as leveraging prompt engineering or incorporating external information to further enhance the precision of LLMs in security defect detection. Yang et al. (2024) introduced a framework utilizing DL models, integrating context learning and CoT to augment prompts in security defect detection. Their framework yielded superior performance compared to state-of-the-art prompting techniques. Nong et al. (2024a) proposed a vulnerability-semantics-guided prompting (VSP) approach that combines CoT with various auxiliary information to evaluate the performance of LLMs in identifying security defects (including their classification and resolution). The research concerns and employed datasets of the above two studies (Yang et al., 2024; Nong et al., 2024a) differ significantly from ours. These studies focus on designing benchmarks to enhance LLM in vulnerability detection, utilizing synthetic datasets and CVE datasets composed of publicly disclosed vulnerabilities to validate their improvements. Compared with them, **our work** focuses on the empirical evaluation of LLMs in the context of security code review, employing a dataset of security defects collected from code reviews of real-world software projects. To further improve the accuracy of LLMs in security defect detection, some studies have adopted RAG to retrieve external knowledge and enhance the input prompts. Du et al. (2024) constructed multi-dimensional representations to retrieve knowledge most relevant to the target code from historical vulnerabilities and their corresponding fixes. This framework improved the accuracy of LLMs in distinguishing vulnerable code from patched code by 16%–24%. Lu et al. (2024) incorporated graph-structured information from the code and identified highly related code samples as external guidance into the prompt. Using this method, LLMs outperformed state-of-the-art deep learning-based tools in detecting vulnerabilities. With the emergency of reasoning-optimized LLMs, LLM-based agents have also shown promising applications in security defect detection. Inspired by courtroom, Widyasari et al. (2025) constructed a framework consisting of four distinct agent roles, which are security researcher, code author, moderator, and review board. Their framework employs multiple rounds of interaction to arrive at a final determination on security defects in the code, which substantially surpassed the performance of approaches based on CoT and fine-tuning. Tsai et al. (2025) incorporated RAG into the multi-turn multi-role interaction agent framework, achieving a 29.9% improvement in F1 score compared to Widyasari et al. (2025). It is worth noting that the studies mentioned above focus on general vulnerability detection by LLMs, whereas **our work** targets the specific area of security code review by LLMs. Inspired by these related works, we aim to leverage LLMs' potential in security analysis to identify the obstacles, application strategies, and improvement directions for integrating LLMs into security code review.



## 7. Conclusions and Future Work

In our study, we comprehensively analyzed the practicality of current popular LLMs in the context of security code review. We investigated the capabilities of 7 LLMs in detecting security defects similar to those identified by human reviewers during real-world code reviews. For the two top-performing LLMs, each paired with their respective optimal prompts, we conducted a linguistic analysis of the quality problems in their generated responses. Furthermore, we performed separate regression analyses to explore the factors influencing the performance of each LLM-prompt combination.

Our main findings are: (1) In security code review tasks, LLMs demonstrate stronger capabilities than state-of-the-art static analysis tools. Among these LLMs, the reasoning-optimized model outperforms established general-purpose models. However, their practical application remains limited. (2) DeepSeek-R1 is the top-performing LLM in security code review, followed by GPT-4. DeepSeek-R1 performs best when the prompt includes the commit message and CoT guidance, whereas GPT-4 performs best when provided with a CWE list in the prompt. (3) DeepSeek-R1 and GPT-4 are more effective at detecting security defects in files with fewer tokens and with security-related code annotations. Notably, DeepSeek-R1 was found to be less focused on Race Condition than other types of security defect. (4) The most prevalent quality problem for both DeepSeek-R1 and GPT-4 is verbosity. In comparison, GPT-4 tends to produce vague expressions and demonstrates poorer instruction-following ability, while DeepSeek-R1 is more prone to errors in recalling code details.

In future work, we plan to explore several directions to further enhance the capabilities of LLMs in security code review: (1) Improving the sensitivity to security defects of LLMs, by investigating the optimal granularity of the CWE list provided in the prompt and incorporating external knowledge or project-specific context to ensure comprehensive consideration of frequent security defect types; (2) Enhancing contextual reasoning by developing approaches to provide more precise code context to inform the analysis procedure; (3) Increasing the stability of the LLMs' outputs via techniques such as self-refinement and voting mechanisms, to generate more consistent and reliable results.

## Data availability

We have shared the link to our dataset in the reference (Yu et al., 2025).

## Acknowledgments

This work is supported by the National Natural Science Foundation of China under Grant No. 62172311 and the Major Science and Technology Project of Hubei Province under Grant No. 2024BAA008. The numerical calculations in this paper have been done on the supercomputing system in the Supercomputing Center of Wuhan University.

## CRedit authorship contribution statement

**Jiaxin Yu:** Conceptualization, Methodology, Investigation, Data curation, Formal analysis, Writing - Original draft preparation. **Peng Liang:** Conceptualization, Methodology, Investigation, Data curation, Supervision, Writing - Original draft preparation. **Yujia Fu:** Investigation, Data curation, Writing - review and editing. **Amjed Tahir:** Conceptualization, Methodology, Writing - review and editing. **Mojtaba Shahin:** Conceptualization, Methodology, Writing - review and editing. **Chong Wang:** Conceptualization, Methodology, Writing - review and editing. **Yangxiao Cai:** Investigation, Data curation.

## References

- Ahmed, T., Devanbu, P., Treude, C., Pradel, M., 2025. Can llms replace manual annotation of software engineering artifacts?, in: Proceedings of the 22nd IEEE/ACM International Conference on Mining Software Repositories (MSR), IEEE. pp. 526–538.
- Alfadel, M., Nagy, N.A., Costa, D.E., Abdalkareem, R., Shihab, E., 2023. Empirical analysis of security-related code reviews in npm packages. *Journal of Systems and Software* 203, 111752.
- Allison, P., 2014. Prediction vs. causation in regression analysis. *Statistical Horizons* 703.
- Alves, H., Fonseca, B., Antunes, N., 2016. Software metrics and security vulnerabilities: dataset and exploratory study, in: Proceedings of the 12th European Dependable Computing Conference (EDCC), IEEE. pp. 37–44.
- Astekin, M., Hort, M., Moonen, L., 2024. An exploratory study on how non-determinism in large language models affects log parsing, in: Proceedings of the 2nd ACM/IEEE International Workshop on Interpretability, Robustness, and Benchmarking in Neural Software Engineering (InteNSE), pp. 13–18.
- Atil, B., Chittams, A., Fu, L., Ture, F., Xu, L., Baldwin, B., 2024. Llm stability: A detailed analysis with some surprises. *arXiv e-prints*, arXiv–2408.
- Baak, M., Koopman, R., Snoek, H., Klous, S., 2020. A new correlation coefficient between categorical, ordinal and interval variables with pearson characteristics. *Computational Statistics & Data Analysis* 152, 107043.
- Bakhshandeh, A., Keramatfar, A., Norouzi, A., Chekidehkhoun, M.M., 2023. Using chatgpt as a static application security testing tool. *arXiv preprint arXiv:2308.14434*.
- Blackwell, R.E., Barry, J., Cohn, A.G., 2024. Towards reproducible llm evaluation: Quantifying uncertainty in llm benchmark scores. *arXiv preprint arXiv:2410.03492*.
- Borji, A., 2023. A categorical archive of chatgpt failures. *arXiv preprint arXiv:2302.03494*.
- Bosu, A., Carver, J.C., Hafiz, M., Hilley, P., Janni, D., 2014. Identifying the characteristics of vulnerable code changes: An empirical study, in: Proceedings of the 22nd ACM SIGSOFT international symposium on foundations of software engineering (FSE), pp. 257–268.
- Burnham, K.P., Anderson, D.R., 2004. Multimodel inference: understanding aic and bic in model selection. *Sociological Methods & Research* 33, 261–304.
- Campbell, J.L., Quincy, C., Osseman, J., Pedersen, O.K., 2013. Coding in-depth semistructured interviews: Problems of unitization and intercoder reliability and agreement. *Sociological Methods & Research* 42, 294–320.
- Cao, J., Zhang, W., Cheung, S.C., 2024. Concerned with data contamination? assessing countermeasures in code language model. *arXiv preprint arXiv:2403.16898*.
- Cavusoglu, H., Mishra, B., Raghunathan, S., 2004. The effect of internet security breach announcements on market value: Capital market reactions for breached firms and internet security developers. *International Journal of Electronic Commerce* 9, 70–104.



- Chakraborty, S., Krishna, R., Ding, Y., Ray, B., 2021. Deep learning based vulnerability detection: Are we there yet? *IEEE Transactions on Software Engineering* 48, 3280–3296.
- Chang, C.H., Lucas, M.M., Lee, Y., Yang, C.C., Lu-Yao, G., 2024. Beyond self-consistency: Ensemble reasoning boosts consistency and accuracy of llms in cancer staging, in: *Proceedings of the 22nd International Conference on Artificial Intelligence in Medicine (AIME)*, Springer. pp. 677–687.
- Charoenwet, W., Thongtanunam, P., Pham, V.T., Treude, C., 2024. An empirical study of static analysis tools for secure code review, in: *Proceedings of the 42nd International Conference on Software Engineering (ICSE)*, ACM. pp. 691–703.
- Chen, C., Su, J., Chen, J., Wang, Y., Bi, T., Wang, Y., Lin, X., Chen, T., Zheng, Z., 2023. When chatgpt meets smart contract vulnerability detection: How far are we? *arXiv preprint arXiv:2309.05520*.
- Christensen, R.H.B., Christensen, M.R.H.B., 2015. Package ‘ordinal’. Stand 19.
- Cohen, J., 1960. A coefficient of agreement for nominal scales. *Educational and Psychological Measurement* 20, 37–46.
- Davison, A.C., Hinkley, D.V., 1997. *Bootstrap methods and their application*. 1, Cambridge university press.
- Dennison, D., Evans, I., O’Malley, L., 2024. Semgrep. <https://semgrep.dev/>.
- Du, X., Zheng, G., Wang, K., Zou, Y., Wang, Y., Deng, W., Feng, J., Liu, M., Chen, B., Peng, X., et al., 2024. Vul-rag: Enhancing llm-based vulnerability detection via knowledge-level rag. *arXiv preprint arXiv:2406.11147*.
- Edmundson, A., Holtkamp, B., Rivera, E., Finifter, M., Mettler, A., Wagner, D., 2013. An empirical study on the effectiveness of security code review, in: *Proceedings of the 5th International Symposium on Engineering Secure Software and Systems (ESSoS)*, Springer. pp. 197–212.
- Efron, B., Tibshirani, R.J., 1994. *An Introduction to the Bootstrap*. Chapman and Hall/CRC.
- Fu, M., Tantithamthavorn, C., 2022. Linevul: A transformer-based line-level vulnerability prediction, in: *Proceedings of the 19th International Conference on Mining Software Repositories (MSR)*, ACM. pp. 608–620.
- Gao, Z., Wang, H., Zhou, Y., Zhu, W., Zhang, C., 2023. How far have we gone in vulnerability detection using large language models. *arXiv preprint arXiv:2311.12420*.
- GitHub, 2021. CodeQL. <https://codeql.github.com/>.
- GitLab, 2022. GitLab: Mapping the DevSecOps Landscape - 2022 Survey. <https://about.gitlab.com/developer-survey>.
- Glaser, B.G., 1965. The constant comparative method of qualitative analysis. *Social Problems* 12, 436–445.
- Guo, Q., Cao, J., Xie, X., Liu, S., Li, X., Chen, B., Peng, X., 2024. Exploring the potential of chatgpt in automated code refinement: An empirical study, in: *Proceedings of the 46th IEEE/ACM International Conference on Software Engineering (ICSE)*, ACM. pp. 1–13.
- Haller, I., Slowinska, A., Neugschwandtner, M., Bos, H., 2013. Dowsing for {Overflows}: A guided fuzzer to find buffer boundary violations, in: *Proceedings of the 22nd USENIX Security Symposium (USENIX Security)*, USENIX. pp. 49–64.
- Hamasaki, K., Kula, R.G., Yoshida, N., Cruz, A.C., Fujiwara, K., Iida, H., 2013. Who does what during a code review? datasets of oss peer review repositories, in: *Proceedings of the 10th Working Conference on Mining Software Repositories (MSR)*, IEEE. pp. 49–52.
- Han, X., Tahir, A., Liang, P., Counsell, S., Blincoe, K., Li, B., Luo, Y., 2022. Code smells detection via modern code review: A study of the openstack and qt communities. *Empirical Software Engineering* 27, 127.
- Harrell, F.E., 2001. *Regression Modeling Strategies: With Applications to Linear Models, Logistic Regression, and Survival Analysis*. volume 608. Springer.
- Harrell Jr, F.E., Harrell Jr, M.F.E., Hmisc, D., 2017. Package ‘rms’. Vanderbilt University 229.
- Hinkle, D.E., Wiersma, W., Jurs, S.G., 2003. *Applied Statistics for the Behavioral Sciences*. volume 663. Houghton Mifflin Boston.
- Hirao, T., McIntosh, S., Ihara, A., Matsumoto, K., 2020. Code reviews with divergent review scores: An empirical study of the openstack and qt communities. *IEEE Transactions on Software Engineering* 48, 69–81.
- Huang, L., Yu, W., Ma, W., Zhong, W., Feng, Z., Wang, H., Chen, Q., Peng, W., Feng, X., Qin, B., et al., 2025. A survey on hallucination in large language models: Principles, taxonomy, challenges, and open questions. *ACM Transactions on Information Systems* 43, 1–55.
- Jensen, R.I.T., Tawosi, V., Alamir, S., 2024. Software vulnerability and functionality assessment using llms, in: *Proceedings of the 3rd IEEE/ACM International Workshop on Natural Language-Based Software Engineering (NLBSE)*, IEEE. pp. 25–28.
- Jiang, N., Liu, K., Lutellier, T., Tan, L., 2023. Impact of code language models on automated program repair. *arXiv preprint arXiv:2302.05020*.
- Johnson, B., Song, Y., Murphy-Hill, E., Bowdidge, R., 2013. Why don’t software developers use static analysis tools to find bugs?, in: *Proceedings of the 35th International Conference on Software Engineering (ICSE)*, IEEE. pp. 672–681.
- Kabir, S., Udo-Imeh, D.N., Kou, B., Zhang, T., 2024. Is stack overflow obsolete? an empirical study of the characteristics of chatgpt answers to stack overflow questions, in: *Proceedings of the 42nd CHI Conference on Human Factors in Computing Systems (CHI)*, ACM. p. Article No.: 935.
- Kalla, D., Kuraku, S., 2023. Advantages, disadvantages and risks associated with chatgpt and ai on cybersecurity. *Journal of Emerging Technologies and Innovative Research* 10.
- Kang, S., Yoon, J., Yoo, S., 2023. Large language models are few-shot testers: Exploring llm-based general bug reproduction, in: *Proceedings of the 45th International Conference on Software Engineering (ICSE)*, IEEE. pp. 2312–2323.
- Khare, A., Dutta, S., Li, Z., Solko-Breslin, A., Alur, R., Naik, M., 2025. Understanding the effectiveness of large language models in detecting security vulnerabilities, in: *Proceedings of the 18th IEEE Conference on Software Testing, Verification and Validation (ICST)*, IEEE. pp. 103–114.
- Krippendorff, K., 2004. Measuring the reliability of qualitative text analysis data. *Quality and Quantity* 38, 787–800.
- Kumar, K., Ashraf, T., Thawakar, O., Anwer, R.M., Cholakkal, H., Shah, M., Yang, M.H., Torr, P.H., Khan, F.S., Khan, S., 2025. Llm post-training: A deep dive into reasoning large language models. *arXiv preprint arXiv:2502.21321*.
- La Malfa, E., Petrov, A., Frieder, S., Weinhuber, C., Burnell, R., Nazar, R., Cohn, A., Shadbolt, N., Wooldridge, M., 2024. Language-models-as-a-service: Overview of a new paradigm and its challenges. *Journal of Artificial Intelligence Research* 80, 1497–1523.
- Legendre, P., Legendre, L., 2012. *Numerical Ecology*. Elsevier.
- Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., Küttler, H., Lewis, M., Yih, W.t., Rocktäschel, T., et al., 2020. Retrieval-augmented generation for knowledge-intensive nlp tasks. *Advances in Neural Information Processing Systems* 33, 9459–9474.
- Li, Y., Li, X., Wu, H., Xu, M., Zhang, Y., Cheng, X., Xu, F., Zhong, S., 2025. Everything you wanted to know about llm-based vulnerability detection but were afraid to ask. *arXiv preprint arXiv:2504.13474*.
- Liu, F., Liu, Y., Shi, L., Huang, H., Wang, R., Yang, Z., Zhang, L., Li, Z., Ma, Y., 2024. Exploring and evaluating hallucinations in llm-powered code generation. *arXiv preprint arXiv:2404.00971*.
- Liu, P., Yuan, W., Fu, J., Jiang, Z., Hayashi, H., Neubig, G., 2023. Pre-train, prompt, and predict: A systematic survey of prompting methods in natural language processing. *ACM Computing Surveys* 55, 1–35.
- Lu, G., Ju, X., Chen, X., Pei, W., Cai, Z., 2024. Grace: Empowering llm-based software vulnerability detection with graph structure and in-context learning. *Journal of Systems and Software* 212, 112031.
- Luo, Y., Xu, W., Andersson, K., Hossain, M.S., Xu, D., 2024. Fellmvp: An ensemble llm framework for classifying smart contract vulnerabilities, in: *Proceedings of the 7th IEEE International Conference on Blockchain (Blockchain)*, IEEE. pp. 89–96.
- Mahajan, S., Abolhassani, N., Prasad, M.R., 2020. Recommending stack overflow posts for fixing runtime exceptions using failure scenario

- matching, in: Proceedings of the 28th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering (ESEC/FSE), ACM. pp. 1052–1064.
- Marjamäki, D., Jelger, P., Janagård, M., 2024. Cppcheck. Cppcheck Solutions AB. <https://www.cppcheck.com/>.
- McCabe, T.J., 1976. A complexity measure. *IEEE Transactions on Software Engineering* , 308–320.
- McIntosh, S., Kamei, Y., Adams, B., Hassan, A.E., 2016. An empirical study of the impact of modern code review practices on software quality. *Empirical Software Engineering* 21, 2146–2189.
- Mechri, A., Ferrag, M.A., Debbah, M., 2025. Secureqwen: Leveraging llms for vulnerability detection in python codebases. *Computers & Security* 148, 104151.
- Meneely, A., Srinivasan, H., Musa, A., Tejeda, A.R., Mokary, M., Spates, B., 2013. When a patch goes bad: Exploring the properties of vulnerability-contributing commits, in: Proceedings of the 7th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM), IEEE. pp. 65–74.
- Mitrović, S., Andreoletti, D., Ayoub, O., 2023. Chatgpt or human? detect and explain. explaining decisions of machine learning model for detecting short chatgpt-generated text. *arXiv preprint arXiv:2301.13852* .
- Nagelkerke, N.J., et al., 1991. A note on a general definition of the coefficient of determination. *Biometrika* 78, 691–692.
- Ni, C., Yin, X., Yang, K., Zhao, D., Xing, Z., Xia, X., 2023. Distinguishing look-alike innocent and vulnerable code by subtle semantic representation learning and explanation, in: Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering (ESEC/FSE), ACM. pp. 1611–1622.
- Nong, Y., Aldeen, M., Cheng, L., Hu, H., Chen, F., Cai, H., 2024a. Chain-of-thought prompting of large language models for discovering and fixing software vulnerabilities. *arXiv preprint arXiv:2402.17230* .
- Nong, Y., Cai, H., Ye, P., Li, L., Chen, F., 2021. Evaluating and comparing memory error vulnerability detectors. *Information and Software Technology* 137, 106614.
- Nong, Y., Fang, R., Yi, G., Zhao, K., Luo, X., Chen, F., Cai, H., 2024b. Vgx: Large-scale sample generation for boosting learning-based software vulnerability analyses, in: Proceedings of the 46th International Conference on Software Engineering (ICSE), ACM. pp. 1–13.
- Nong, Y., Ou, Y., Pradel, M., Chen, F., Cai, H., 2022. Generating realistic vulnerabilities via neural code editing: an empirical study, in: Proceedings of the 30th ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering (ESEC/FSE), ACM. pp. 1097–1109.
- OpenAI, 2023. gpt-best-practices. <https://platform.openai.com/docs/guides/prompt-engineering/>.
- OpenAI, 2024. tiktoken. <https://github.com/openai/tiktoken/>.
- Ouyang, S., Zhang, J.M., Harman, M., Wang, M., 2025. An empirical study of the non-determinism of chatgpt in code generation. *ACM Transactions on Software Engineering and Methodology* 34, 1–28.
- Pan, S., Bao, L., Xia, X., Lo, D., Li, S., 2023. Fine-grained commit-level vulnerability type prediction by cwe tree structure, in: Proceedings of the 45th International Conference on Software Engineering (ICSE), IEEE. pp. 957–969.
- Paul, R., Turzo, A.K., Bosu, A., 2021. Why security defects go unnoticed during code reviews?: A case-control study of the chromium os project, in: Proceedings of the 43rd International Conference on Software Engineering (ICSE), IEEE. pp. 1373–1385.
- Planning, S., 2002. The economic impacts of inadequate infrastructure for software testing. National Institute of Standards and Technology 1.
- Powers, D., Xie, Y., 2008. Statistical Methods for Categorical Data Analysis. Emerald Group Publishing.
- Puigcerver, J., Riquelme, C., Mustafa, B., Houlsby, N., 2023. From sparse to soft mixtures of experts. *arXiv preprint arXiv:2308.00951* .
- Purba, M.D., Ghosh, A., Radford, B.J., Chu, B., 2023. Software vulnerability detection using large language models, in: Proceedings of the 34th International Symposium on Software Reliability Engineering Workshops (ISSREW), IEEE. pp. 112–119.
- PyCQA, 2024. Bandit. <https://github.com/PyCQA/bandit/>.
- Rafi, M.N., Kim, D.J., Chen, T.H., Wang, S., 2024. The impact of input order bias on large language models for software fault localization. *arXiv preprint arXiv:2412.18750* .
- Ren, Z., Ju, X., Chen, X., Shen, H., 2024. Prorlearn: boosting prompt tuning-based vulnerability detection by reinforcement learning. *Automated Software Engineering* 31, Article No.: 38.
- Russo, A., Sabelfeld, A., 2010. Dynamic vs. static flow-sensitive security analysis, in: Proceedings of the 23rd IEEE Computer Security Foundations Symposium (CSF), IEEE. pp. 186–199.
- SA, S., 2024. SonarQube. <https://www.sonarqube.org/>.
- Schäfer, M., Nadi, S., Eghbali, A., Tip, F., 2023. An empirical evaluation of using large language models for automated unit test generation. *IEEE Transactions on Software Engineering* .
- Setia, M.S., 2016. Methodology series module 2: Case-control studies. *Indian Journal of Dermatology* 61, 146–151.
- Sheng, Z., Chen, Z., Gu, S., Huang, H., Gu, G., Huang, J., 2025. Llms in software security: A survey of vulnerability detection techniques and insights. *ACM Computing Surveys* 58, 1–35.
- Sheng, Z., Wu, F., Zuo, X., Li, C., Qiao, Y., Hang, L., 2024. Lpro- tector: An llm-driven vulnerability detection system. *arXiv preprint arXiv:2411.06493* .
- Siddiq, M.L., Santos, J.C., 2022. Securityeval dataset: mining vulnerability examples to evaluate machine learning-based code generation techniques, in: Proceedings of the 1st International Workshop on Mining Software Repositories Applications for Privacy and Security (MSR4P), pp. 29–33.
- Song, Y., Wang, G., Li, S., Lin, B.Y., 2024. The good, the bad, and the greedy: Evaluation of llms should not ignore non-determinism. *arXiv preprint arXiv:2407.10457* .
- Sovrano, F., Bauer, A., Bacchelli, A., 2025. Large language models for in-file vulnerability localization can be “lost in the end”. *Proceedings of the ACM on Software Engineering* 2, 891–913. URL: <http://dx.doi.org/10.1145/3715758>, doi:10.1145/3715758.
- Spadini, D., Aniche, M., Storey, M.A., Bruntink, M., Bacchelli, A., 2018. When testing meets code review: Why and how developers review tests, in: Proceedings of the 40th International Conference on Software Engineering (ICSE), IEEE. pp. 677–687.
- Steenhoek, B., Rahman, M.M., Roy, M.K., Alam, M.S., Barr, E.T., Le, W., 2024a. A comprehensive study of the capabilities of large language models for vulnerability detection. *CoRR* .
- Steenhoek, B., Rahman, M.M., Roy, M.K., Alam, M.S., Tong, H., Das, S., Barr, E.T., Le, W., 2024b. To err is machine: Vulnerability detection challenges llm reasoning. *arXiv preprint arXiv:2403.17218* .
- Sui, L., Dietrich, J., Tahir, A., Fourtounis, G., 2020. On the recall of static call graph construction in practice, in: Proceedings of the 33rd International Symposium on Software Testing and Analysis (ISSTA), ACM. pp. 1049–1060.
- Sun, Y., Wu, D., Xue, Y., Liu, H., Ma, W., Zhang, L., Liu, Y., Li, Y., 2024. Llm4vuln: A unified evaluation framework for decoupling and enhancing llms’ vulnerability reasoning. *arXiv preprint arXiv:2401.16185* .
- Telang, R., Wattal, S., 2007. An empirical analysis of the impact of software vulnerability announcements on firm stock price. *IEEE Transactions on Software Engineering* 33, 544–557.
- Terry, Y., 2024. lizard. <https://github.com/terryyin/lizard/>.
- Thongtanunam, P., McIntosh, S., Hassan, A.E., Iida, H., 2017. Review participation in modern code review: An empirical study of the android, qt, and openstack projects. *Empirical Software Engineering* 22, 768–817.
- Tonmoy, S., Zaman, S., Jain, V., Rani, A., Rawte, V., Chadha, A., Das, A., 2024. A comprehensive survey of hallucination mitigation techniques in large language models. *arXiv preprint arXiv:2401.01313* 6.
- Tsai, C.N., Xie, J., Lai, C.M., Lin, C.S., 2025. Leveraging intra-and inter-references in vulnerability detection using multi-agent collaboration based on llms. *Cluster Computing* 28, 1–12.
- Turzo, A.K., 2022. Towards improving code review effectiveness through task automation, in: Proceedings of the 37th IEEE/ACM International

- Conference on Automated Software Engineering (ASE), ACM. pp. 1–5.
- Weir, C., Rashid, A., Noble, J., 2017. I'd Like to Have an Argument, Please: Using Dialectic for Effective App Security. Internet Society.
- Wen, X.C., Wang, X., Chen, Y., Hu, R., Lo, D., Gao, C., 2024. Vuleval: Towards repository-level evaluation of software vulnerability detection. arXiv preprint arXiv:2404.15596 .
- Widyasari, R., Weyssow, M., Irsan, I.C., Ang, H.W., Liauw, F., Ouh, E.L., Shar, L.K., Kang, H.J., Lo, D., 2025. Let the trial begin: A mock-court approach to vulnerability detection using llm-based agents. arXiv preprint arXiv:2505.10961 .
- Xie, D., Yoo, B., Jiang, N., Kim, M., Tan, L., Zhang, X., Lee, J.S., 2023. Impact of large language models on generating software specifications. arXiv preprint arXiv:2306.03324 .
- Yang, Y., Zhou, X., Mao, R., Xu, J., Yang, L., Zhangm, Y., Shen, H., Zhang, H., 2024. Dlap: A deep learning augmented large language model prompting framework for software vulnerability detection. arXiv preprint arXiv:2405.01202 .
- Yin, X., Ni, C., Wang, S., 2024. Multitask-based evaluation of open-source llm on software vulnerability. IEEE Transactions on Software Engineering .
- Yu, J., Fu, L., Liang, P., Tahir, A., Shahin, M., 2023. Security defect detection via code review: A study of the openstack and qt communities, in: Proceedings of the 17th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM), IEEE. pp. 1–12.
- Yu, J., Liang, P., Fu, Y., Tahir, A., Shahin, M., Wang, C., Cai, Y., 2025. Replication Package for the Paper: “An Insight into Security Code Review with LLMs: Capabilities, Obstacles and Influential Factors”. <https://doi.org/10.5281/zenodo.15572150>.
- Zhang, C., Liu, H., Zeng, J., Yang, K., Li, Y., Li, H., 2024. Prompt-enhanced software vulnerability detection using chatgpt, in: Proceedings of the 46th IEEE/ACM International Conference on Software Engineering: Companion Proceedings(ICSE), pp. 276–277.
- Zhou, X., Cao, S., Sun, X., Lo, D., 2025. Large language model for vulnerability detection and repair: Literature review and the road ahead. ACM Transactions on Software Engineering and Methodology 34, 1–31.
- Zhou, X., Kim, K., Xu, B., Liu, J., Han, D., Lo, D., 2023. The devil is in the tails: How long-tailed code distributions impact large language models, in: Proceedings of the 38th IEEE/ACM International Conference on Automated Software Engineering (ASE), IEEE. pp. 40–52.
- Zhou, X., Zhang, T., Lo, D., 2024. Large language model for vulnerability detection: Emerging results and future directions, in: Proceedings of the 44th ACM/IEEE International Conference on Software Engineering: New Ideas and Emerging Results (ICSE-NIER), pp. 47–51.